

Appendix J Completed Reviewer Response Forms

Evaluating the Effectiveness of Large Language Models in Generating and Auditing PCI DSS-Aligned Information Security Policies. MSc Information Security, Royal Holloway, University of London, 2025/26.

This file holds the twelve completed Reviewer Response Capture Forms returned in Phase 4, one for each reviewer and policy, in the order reviewer R1, R2, R3 and policy P1a, P1b, P2a, P2b. Reviewers are identified by code only; the record linking code to person is held outside the appendix set, as the participant information sheet and consent form require. The forms are reproduced as returned, without correction. Each form begins with the guidance and calibration pages that were issued with it. The scores and findings recorded here are transcribed in the scoring workbook at Appendix I and analysed in Chapters 5 and 6.

Form	Reviewer	Policy	Pages	Starts at page
1	R1	P1a	17	2
2	R1	P1b	18	19
3	R1	P2a	16	37
4	R1	P2b	17	53
5	R2	P1a	14	70
6	R2	P1b	14	84
7	R2	P2a	14	98
8	R2	P2b	16	112
9	R3	P1a	17	128
10	R3	P1b	19	145
11	R3	P2a	17	164
12	R3	P2b	20	181

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	25	45
Second, Section D.9	46	90	90	75	72

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P1a

Date completed: 22 Aug 2026

Reviewer identifier: R1 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	Taken against the 9 applicable sub-requirements the extract reproduces for Requirement 7, 8 are fully addressed and 1 is largely addressed (7.1.2), with none partial and none left unaddressed. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96.
Accuracy	90	Entered at the midpoint of the 81 to 100 band, with nothing found that would move it either way. No control statement in section 2 is invented, every sub-requirement number resolves to the obligation set beside it, the 6-month interval at 2.3 and the least-privilege wording at 2.1 are the version 4.0.1 formulations, and clause 2.4 routes the application-account review frequency through 12.3.1, which is where the standard puts it.
Proportionality and scope fit	90	The midpoint of the 81 to 100 band, unmoved. The 6-month review and the group-membership clean-up at 2.1 sit within the reach of a security function of 2, and so does the approval route at 2.2. Clause 2.5 makes the cardholder-data repository control conditional and then refuses to let the absence of stored PAN weaken it, which reads the scope of this environment correctly.
Enforceability and clarity	65	The review elements at 2.3 are enumerated and the interval is numerical, so an assessor would be able to test them, and that carries the entry 1 step above the midpoint of the 61 to 80

Criterion	Score, 0 to 100	Evidence or comment
		band. 2 steps come back down, because no clause anywhere in section 2 names a person, and because the approver at 2.2 is only "authorized personnel". The frequency required by 7.2.5.1 rests on a targeted risk analysis that section 5.3 does no more than promise, so no interval yet exists to be tested.
Requirement-area score	87	$(96 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (65 \times 0.20) = 33.6 + 22.5 + 18 + 13 = 87.1$, rounded once to 87.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.2	Clause 1.3 states that operational responsibilities "shall be documented, assigned and communicated", which defers the assignment instead of making it. No role is named for any Requirement 7 activity, and "communicated" is weaker than the standard's "understood".	A	Minor
7.2.3	Clause 2.2 requires approval by "authorized personnel" and nowhere states who holds that authority. Whether a given approval was validly given is therefore not testable.	A	Minor
7.2.4	Clause 2.3 states the 6-month interval and the 4 review elements entirely in the passive, so no role is required to perform the review, and none is required to address its exceptions or to hold the management acknowledgement. No owner is named.	A	Minor
7.2.5.1	The review frequency is deferred to a targeted risk analysis which clause 5.3 also does no more than promise. Until that analysis exists, no testable interval binds the review of application and system accounts.	A	Minor
7.2.6	Although the condition is defensible for this environment, the control is conditional on a repository existing ("Where a repository of stored	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	cardholder data exists within scope"), and no role is made responsible for determining that one has come into existence.		

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	Checklist result at Section D.13.5: 71 of 72 points, $100 \times 71 / 72 = 98.6$, rounded once to 99, from 23 fully addressed and 1 largely addressed (8.1.2). The figure disagrees with the impression the section leaves, and both stand. Every applicable obligation is stated, and stated almost entirely in the passive, which coverage does not measure and enforceability does.
Accuracy	90	Nothing here moves the entry off the midpoint of the 81 to 100 band, no defect of the 4 kinds being present. The 12-character minimum with its 8-character fallback, the 10-attempt lockout and 30-minute duration, the 90-day inactivity and 90-day password intervals and the 15-minute session limit are all the version 4.0.1 figures, and clause 3.12 attributes 8.6.1, 8.6.2 and 8.6.3 to the obligations they carry whilst routing rotation frequency through 12.3.1 exactly as the standard does.
Proportionality and scope fit	90	The midpoint of the 81 to 100 band, with no factor to move it. Enforcement throughout section 3 runs through the federated identity provider the scenario states is already in place and already supplying multi-factor authentication and conditional access, so that clause

Criterion	Score, 0 to 100	Evidence or comment
		3.11, which extends MFA beyond the AWS console and the collaboration suite, and 3.5, which removes the indefinite order-management session, both rest on a capability that has been stated. Nothing in the section assumes a primary account number rests on a NorthPay system.
Enforceability and clarity	65	Parameters are numerical throughout section 3, so each one would test directly against a configuration, and the entry moves up 1 step from the midpoint of the 61 to 80 band on that. It comes down 2, since no clause in the section carries a role at all, and constructions such as "authentication controls shall lock" and "NorthPay shall document and communicate" leave nobody to be held to the obligation. The exception routes at 3.2 and 3.12 require "explicit management approval" without naming an approver, and limit use only to "the time required".
Requirement-area score	88	$(99 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (65 \times 0.20) = 34.65 + 22.5 + 18 + 13 = 88.15$, rounded once to 88.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.1.2	As at 7.1.2. Clause 1.3 carries the same wording, "shall be documented, assigned and communicated", and no role owns any Requirement 8 activity. The standard's "understood" is not stated.	A	Minor
8.2.2	Clause 3.2 requires "explicit management approval" without stating which manager holds it, and limits use to "the time required" without setting a maximum or a review point. No approver is named and no ceiling is set.	A	Minor
8.2.8	Clause 3.5 applies the 15-minute rule "where Requirement 8.2.8 applies". The qualifier is self-referential, so the set of	T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	in-scope sessions is left undetermined, and although the order-management platform is described, it is not named as bound by the clause.		
8.3.4	Clause 3.7 sets lockout at "no more than 10 invalid authentication attempts", where the identity provider is already stricter at 6. The systems the clause binds are not named and the stricter existing setting is not preserved, so the clause reads as licence to relax it.	T	Minor
8.6.2	Although the prohibition on hard-coded credentials is stated in full, the deployment credentials held as repository secrets are not addressed anywhere, so whether that arrangement satisfies 3.12 or breaches it is left to inference.	T	Minor
8.3.8	Clause 3.9 states what the guidance must address, and then assigns no author and names no distribution point, and nothing requires the audience to be tested, so "documented and communicated to users" is not evidenced from the policy alone.	A	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	Taken against the 9 applicable sub-requirements reproduced for Requirement 10, 8 are fully addressed and 1 is largely addressed (10.1.2), with none partial and none unaddressed. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96.
Accuracy	90	Midpoint of the 81 to 100 band, with no factor cited and none of the 4 defect kinds appearing. 12-month retention with 3 months immediately available at 4.6 is the version 4.0.1 figure, the daily review categories at 4.3 reproduce

Criterion	Score, 0 to 100	Evidence or comment
		10.4.1 correctly, and the 7 response elements at 4.7 match 10.7.3 with nothing added.
Proportionality and scope fit	85	1 step down from the midpoint of the 81 to 100 band. Clause 4.3 requires the daily review "irrespective of normal office hours" and "supported by procedures that ensure required reviews occur every day", with neither a rota nor a delegation route, and no allowance for an automated first-stage review. Where the security function is 2 people, 1 of them working 3 days a week, that is a control the stated capability does not support as written. The archival requirement at 4.6 is a modest and necessary addition and is not counted against this criterion.
Enforceability and clarity	65	The intervals are stated numerically and the failure-response steps at 4.7 are enumerated, which lifts the entry 1 step from the midpoint of the 61 to 80 band. 2 steps down follow, the first of them because clause 4.1 promises that logging responsibilities "shall be assigned" instead of assigning them, which leaves the daily review with no reviewer. Clause 4.4 then requires "relevant administrator activity logs" to be brought within "the applicable review arrangements", and neither term is defined anywhere in the document.
Requirement-area score	86	$(96 \times 0.35) + (90 \times 0.25) + (85 \times 0.20) + (65 \times 0.20) = 33.6 + 22.5 + 17 + 13 = 86.1$, rounded once to 86.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.1.2	Clause 4.1 states that responsibilities "shall be assigned and understood" without requiring that they be documented, and it names no role. The obligation is present in weaker terms than the sub-requirement states.	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.4.1	No reviewer is named and no mechanism is stated, whilst clause 4.3 requires the review every day regardless of office hours, and the only alerting route in the environment is a shared mailbox watched 08:00 to 18:00 on working days, with neither a rota nor an automated first-stage review provided to close the gap.	A, T	Minor
10.4.2	Clause 4.4 requires "relevant administrator activity logs maintained within SaaS platforms" to be included in "the applicable review arrangements", and both qualifiers are left undefined. The order-management administrator log, which is not forwarded to the monitoring platform, is never named.	T	Minor
10.5.1	Clause 4.6 requires retention beyond the 90-day searchable period, and states no archive, no protection against alteration or deletion, no owner and no date by which the gap closes, so the obligation stands with no stated means of meeting it.	T	Minor
10.7.3	"Critical security control systems" is never defined for NorthPay, so the trigger for the 7-step response at 4.7 is not testable. An assessor would ask which failures start the clock, and the policy holds no answer.	T	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	Taken against the 30 applicable sub-requirements reproduced for Requirement 12, 29 are fully addressed and 1 is largely addressed (12.1.3), with none partial and none unaddressed. 89 of 90 points, $100 \times 89 / 90 = 98.9$, rounded once to 99.
Accuracy	90	Midpoint of the 81 to 100 band, unmoved. The 12-month intervals

Criterion	Score, 0 to 100	Evidence or comment
		throughout section 5 match version 4.0.1, the customized-approach clause at 5.4 requires both a controls matrix and senior-management approval, as the standard does, and 8.5 treats the payment-page change-and-tamper mechanism by reference to its applicability status without asserting that it is currently mandatory, so that nothing across the section is invented or misattributed.
Proportionality and scope fit	90	Midpoint of the 81 to 100 band. Clause 8.3 requires designated 24/7 responders, which is what 12.10.3 requires, and it stops short of mandating a staffed operations centre, whilst nothing across sections 5 to 8 assumes a tool or a contract the scenario does not state, and no team is presumed that does not exist. Scope is described consistently with an environment holding no primary account number, and 1.2 refuses to use that fact to exclude connected components, which is the right reading.
Enforceability and clarity	70	The executive owner is named at 1.3 and the coordinating role is named with concrete duties, which discharges 12.1.4 in a form an assessor would be able to test, and the entry moves up 1 step from the midpoint of the 61 to 80 band. It moves back down 1, because no individual clause in sections 5 to 8 names a person, so the annual calendar of reviews, analyses, monitoring and testing has no holder, and 9.2 refers approval back to "NorthPay's assigned information security governance responsibilities", which is circular.
Requirement-area score	89	$(99 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (70 \times 0.20) = 34.65 + 22.5 + 18 + 14 = 89.15$, rounded once to 89.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.1.3	The policy defines the Chief Technology Officer and the Information Security Manager and nobody else. For all other personnel, clause 1.3 states that responsibilities "shall be documented, assigned and communicated", which defers the definition instead of making it, where the sub-requirement asks this instrument itself to define roles and responsibilities for all personnel.	A	Major
12.3.1	Although the analysis is specified in full at 5.3, and 4 other clauses depend on it (7.2.5.1, 8.6.3, 10.4.2.1, 12.10.4.1), no owner and no completion date is set for producing it. Those 4 frequencies are left undetermined by the policy.	A	Minor
12.10.1	The plan's legal element is stated only as "analysis of applicable legal reporting requirements". Where the acquirer and payment-brand notification meets the controller's 72-hour duty to the Information Commissioner, no relationship is mapped, so the element is not testable against the 2 clocks NorthPay actually faces.	L, A	Minor
12.10.3	Clause 8.3 requires designated personnel available 24/7 and coverage outside shared-mailbox hours, and then names no rota, names no primary and deputy, and states no alerting route capable of reaching a responder out of hours, so the obligation stands with nothing in the policy making it operable.	A	Minor
12.8.4	Annual monitoring of third-party PCI DSS status is required at 7.4, with no owner named for it, and the register at 7.1 sets no date by which the suppliers already touching the cloud environment are to be entered.	A	Minor
12.6.3	Training on hire and every 12 months is required, with an annual acknowledgement, and 6.2 requires completion to be tracked and followed	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	up. No completion target is set and no escalation route is stated, and non-completion carries no consequence.		

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	
8.1.2 Roles and responsibilities documented, assigned and understood	Largely addressed	2	Clause 1.3: "Specific operational responsibilities for access control, identity management, authentication ... shall be documented, assigned and communicated." The responsibilities are promised rather than assigned, and no role is named.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
privileges			
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	
8.3.4 Invalid authentication attempts limited by logout	Fully addressed	3	
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	On the written instrument, yes. Every applicable sub-requirement in the extract is addressed and the parameters are the

Question	Response
	version 4.0.1 ones. The first challenge is ownership. Clause 1.3 promises that operational responsibilities "shall be documented, assigned and communicated", and then no operative clause in the document names anyone at all. An assessor testing 7.2.4, 10.4.1 or 12.8.4 would ask who performs the activity, and the policy holds no answer. Second, the policy commits NorthPay to controls the organisation does not currently operate. 12-month log retention. MFA beyond the AWS console and the collaboration suite. A 15-minute session limit on the order-management platform. No remediation date attaches to any of them and no interim position is stated, so at assessment the policy and the environment will not agree, and the policy is the document that will be quoted back.
Anything that reads as compliant on the surface but would not hold.	Clause 4.3. Daily log review "irrespective of normal office hours", supported by "procedures that ensure required reviews occur every day", with no rota, no delegation and no automated first stage. Written as an absolute for a security function of 2, one of them part-time, it fails on the first weekend, and the failure is visible in the review record. Clause 8.3 takes the same shape: 24/7 designated responders, no rota, no deputy, no out-of-hours alerting route. Clause 2.5 reads as a full 7.2.6 control. It is conditional on a repository existing, and nobody is made responsible for noticing that one has.
Any requirement or sub-requirement missed, misstated or invented.	Nothing is invented and no sub-requirement number is misattributed. No sub-requirement in the extract is left unaddressed. Stated too weakly: 12.1.3, where 2 roles are defined and the rest deferred, and then 7.1.2, 8.1.2 and 10.1.2, all of which promise that responsibilities will be documented and assigned in place of documenting and assigning them. Clause 3.7 sets lockout at

Question	Response
	10 attempts where the identity provider is already at 6, which is compliant and reads as permission to relax a stricter control.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Adopt, yes. Enforcing it as written would take 2 additions the policy does not make, a named owner on each recurring clause, and a calendar that places the annual, 6-monthly and daily activities on identified people. The daily log review and the 24/7 designation are the 2 that break first. The remainder, 6-monthly access reviews, annual scope validation, annual supplier monitoring, annual policy and awareness review, is within reach of 2 people where it is scheduled rather than reconstructed before validation, and no scheduling appears anywhere in the document.
Anything else worth recording.	The current state of the environment is written into the policy itself. A 10-character password minimum. A 90-day searchable retention. MFA confined to the AWS console and the collaboration suite. That makes the remediation gap explicit, which is useful, and it dates the document, because each of those clauses becomes wrong as soon as it is acted on and nothing provides for retiring them at review.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Principal Security Consultant
Years of experience with PCI DSS	8 years
Currently or formerly a Qualified Security Assessor	Former QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	25	45
Second, Section D.9	46	90	90	75	72

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P1b

Date completed: 22 Aug 2026

Reviewer identifier: R1 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	The 9 applicable sub-requirements reproduced in the extract for Requirement 7 come out at 8 fully addressed and 1 largely addressed (7.2.5.1), with nothing partial and nothing unaddressed. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96.
Accuracy	90	Midpoint of the 81 to 100 band, with nothing to move it. Every number in section 3 resolves to the obligation it is set against, the 6-month interval is the version 4.0.1 one, and the application-account review frequency is routed through a targeted risk analysis instead of being fixed, which is what the standard provides for.
Proportionality and scope fit	95	1 step up from the midpoint of the 81 to 100 band. Clause 3.3 disposes of the 3 legacy project groups by name, which is an instruction a function of 2 can carry out on Monday morning rather than a principle to be interpreted. Clause 3.6 makes the stored-data control conditional and then requires review by the Information Security Manager and the CTO, together with a scope reassessment, before any PAN storage is introduced, which for an environment holding no primary account number is the correct posture.
Enforceability and clarity	75	2 steps up from the midpoint of the 61 to 80 band and 1 back down. Approval is routed to a named class of approver, the

Criterion	Score, 0 to 100	Evidence or comment
		manager or the system owner, self-approval of privileged access is barred, and evidence of the request and its approval is required, as is evidence of implementation. Clause 3.4 then makes the Information Security Manager responsible for tracking completion of the 6-monthly review. Against that, "separation between ordinary and privileged access where appropriate" at 3.1 and "material application and system accounts" at 3.5 leave 2 obligations with no determinable edge.
Requirement-area score	90	$(96 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (75 \times 0.20) = 33.6 + 22.5 + 19 + 15 = 90.1$, rounded once to 90.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.2.5.1	Clause 3.5 states the review and its targeted-risk-analysis frequency, and then does not require inappropriate access to be addressed, nor management to acknowledge that the access remains appropriate, both of which are stated for user accounts at 3.4 and dropped here. 2 elements are therefore missing.	A	Minor
7.2.3	Clause 3.2 requires approval "by the person's manager and/or appropriate system owner". The "and/or" leaves an assessor unable to tell whose signature is required for privileged access, and only self-approval is expressly barred.	A	Minor
7.2.1	"Separation between ordinary and privileged access where appropriate" at 3.1. The qualifier is not testable, and no role is made responsible for deciding where separation applies.	A	Minor
7.2.5	The register at 3.5 covers "material application and system accounts". "Material" is not defined anywhere, so the completeness of the register is not testable, and an omitted service	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	account is no breach of the clause as drafted.		
7.2.4	Although the 6-monthly review is owned and tracked, no consequence and no escalation attaches where a review is not completed timely, and no backstop is stated.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	94	Checklist result at Section D.13.5: 68 of 72 points, $100 \times 68 / 72 = 94.4$, rounded once to 94. That is 21 fully addressed, 2 largely addressed (8.3.6, 8.3.11) and 1 partially addressed (8.3.1), with none unaddressed.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited. Every parameter matches version 4.0.1, and the treatment of password expiry is correct, in that routine expiry may be removed only where the password is not the sole factor, which is what 8.3.9 says. The hedges at 4.6 and 4.8 assert nothing false about the standard and weaken obligations instead, so they are recorded under coverage and enforceability.
Proportionality and scope fit	95	1 step up from the midpoint of the 81 to 100 band. Clause 4.3 assumes none of the automatic de-provisioning the organisation does not have, requiring the responsible administrator to record manual completion for each service, and it refuses to let the control wait on automation that may arrive later. Enforcement elsewhere rests on the central identity provider, which the

Criterion	Score, 0 to 100	Evidence or comment
		scenario states supplies both multi-factor authentication and conditional access.
Enforceability and clarity	70	2 steps up from the midpoint of the 61 to 80 band, and 2 back down. The joiner, mover and leaver process names HR, managers, system owners and IT, and de-provisioning carries a named recorder. Persistent third-party access requires explicit approval from the Information Security Manager, which is a named approver on an exception. Downwards: "alphabetic and numeric characters where required by PCI DSS" at 4.6 and "all applicable non-console access" at 4.8 hedge 2 obligations the standard states flatly, and 4.5 requires non-compliant sessions to be "remediated or otherwise brought into compliance where the requirement applies", with no date, no owner and no interim control.
Requirement-area score	88	$(94 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (70 \times 0.20) = 32.9 + 22.5 + 19 + 14 = 88.4$, rounded once to 88.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.3.1	Clause 4.6 cites 8.3.1, opens on protecting authentication factors and then addresses passwords alone. Nothing in the policy requires all user and administrator access to in-scope components to be authenticated by a permitted factor, so the general rule the remainder of section 4 assumes is not stated anywhere.	T	Major
8.3.6	"They shall contain alphabetic and numeric characters where required by PCI DSS". An unconditional parameter is made conditional on a determination the policy neither makes nor assigns to anyone.	T	Minor
8.3.11	Only the first element is stated, tokens	T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	and certificates "shall not be shared", whilst the requirement that physical or logical controls ensure only the intended user can use the factor is absent.		
8.4.2	Clause 4.8 requires MFA for "all applicable non-console access into the CDE" and enumerates the systems "where applicable". Where the standard states the obligation without qualification, the clause as drafted leaves the set of access it binds to be decided outside the policy.	T	Minor
8.2.8	Clause 4.5 states the 15-minute rule and then requires systems currently configured for longer or indefinite sessions to be "remediated or otherwise brought into compliance where the requirement applies". No date and no owner attaches to that, no interim control is stated, and although the order-management platform is described, it is not named.	T	Minor
8.6.2	Repository secrets are permitted "only where access, audit, encryption and lifecycle controls have been assessed as suitable for the relevant risk". No assessor is named and no record of the assessment is required, so the exception is not testable.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	100	All 9 of the applicable sub-requirements reproduced in the extract for Requirement 10 are fully addressed. 27 of 27 points, $100 \times 27 / 27 = 100$. The figure runs ahead of what the section delivers, and both stand: every obligation is present with an owner and an interval, whilst several rest on qualifiers ("where technically feasible",

Criterion	Score, 0 to 100	Evidence or comment
		"significant events") that coverage does not weigh and enforceability does.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited. 12 months with 3 immediately available matches version 4.0.1, the daily review categories reproduce 10.4.1, and the 8 response steps at 5.8 cover the 7 elements of 10.7.3 with nothing added. The time-synchronisation paragraph at 5.7 cites no sub-requirement and asserts nothing false, and none of the 4 defect kinds is present.
Proportionality and scope fit	95	1 step up from the midpoint of the 81 to 100 band. Clause 5.3 states expressly that no staffed 24-hour operations centre is required, permits automated correlation to perform the first-stage review, and then closes the gap the scenario actually has by requiring high-severity alerts to reach an on-call responder in place of a mailbox watched 08:00 to 18:00, which for a security function of 2 is the proportionate answer and is stated in terms.
Enforceability and clarity	80	3 steps up from the midpoint of the 61 to 80 band and 1 down. The Information Security Manager is named accountable and the performing parties are named alongside. Clause 5.5 specifies the fields the review record must carry, event, reviewer, date, conclusion and action, which makes the daily review testable from evidence, and 5.4 sets monthly as the default frequency so that the obligation is testable before the targeted risk analysis exists. Downwards: "where technically feasible" at 5.2 and "the responsible team" at 5.8 leave 1 control and 1 owner undetermined.
Requirement-area score	93	$(100 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 35 + 22.5 + 19 + 16 = 92.5$, rounded once to 93.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.1.2	Clause 5.8 assigns the response to critical security control failures to "the responsible team", and no such team is named anywhere. Every other role in section 5 is named, which makes this one an oversight in an otherwise consistent section.	A	Minor
10.4.1	Automated correlation may perform the first-stage review "provided significant events are brought to human attention". "Significant" is not defined and no alert threshold is set. Nobody owns the tuning, which matters because the existing alert set in the environment was not designed against these categories.	T	Minor
10.5.1	The 12-month archive is required and the 90-day searchable gap is named. No storage is identified, no protection mechanism is stated, no owner is named and no date is set for closing the gap, so the obligation is complete and the means of meeting it is absent from the policy.	T	Minor
10.3.1	Although read access is limited to those with "a legitimate security, administration, audit or support need", nobody is made responsible for holding the entitlement list, and it is not drawn into the 6-monthly access review at 3.4.	T	Minor
10.4.2	Monthly review is stated as an "operational default" and not as a policy commitment, displaced by whatever the targeted risk analysis supports. The interval can therefore move with no documented decision point.	A	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	97	The 30 applicable sub-requirements

Criterion	Score, 0 to 100	Evidence or comment
		reproduced for Requirement 12 come out at 28 fully addressed, 1 largely addressed (12.8.2) and 1 partially addressed (12.6.2), with none unaddressed. 87 of 90 points, $100 \times 87 / 90 = 96.7$, rounded once to 97.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited. Every cited sub-requirement resolves, the 12-month intervals match version 4.0.1, and the regulatory boundary at 1.4 is stated correctly, in that the policy expressly disclaims any Financial Conduct Authority permission or obligation. The data-protection material at 1.3, 11.8 and 12 asserts nothing about PCI DSS the standard does not contain.
Proportionality and scope fit	95	1 step up from the midpoint of the 81 to 100 band. Two clauses state the proportionality outright instead of leaving it to inference: 11.3 permits a primary-and-backup on-call rota in place of a staffed operations centre, and 15.1 states that controlled spreadsheets, ticketing and the existing cloud services suffice and that no governance platform need be bought. Screening at 9.4 is scaled to the level of access, and nothing across the section assumes a capability the scenario does not state.
Enforceability and clarity	80	3 steps up from the midpoint of the 61 to 80 band, 1 down. The Information Security Manager is named Incident Response Coordinator, with a named deputy behind, clause 13.3 places the recurring calendar on a named role and specifies what each evidence record must show, and 14.1 requires every exception to carry an owner, an expiry date and named approvals, barring renewal without review. Against that, a number of recurring obligations still read "NorthPay shall" with no holder at all, amongst them the cryptographic inventory at 7.3, role-specific training at

Criterion	Score, 0 to 100	Evidence or comment
		9.3 and supplier due diligence at 10.3.
Requirement-area score	91	$(97 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 33.95 + 22.5 + 19 + 16 = 91.45$, rounded once to 91.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.6.2	The annual review and update of the security awareness programme is absent, section 9 setting the training frequency and the content, and setting a completion expectation, whilst never requiring the programme itself to be reviewed every 12 months or updated against new threats. The generic line at 15, that supporting procedures are reviewed "according to their defined frequencies", defines no frequency for this one.	A	Major
12.8.2	The maintenance element is missing, in that clause 10.2 requires the acknowledgement wording in "applicable TPSP agreements" and never states that written agreements are maintained with every TPSP with which account data is shared or that could affect CDE security. Non-compliant contracts are deferred to "renewal or sooner according to risk", with no backstop date and no owner.	A	Minor
12.3.3	Clause 7.3 says automated certificate renewal "should" be used, and that expiry "shall not depend solely on an individual engineer's spreadsheet where automated monitoring is reasonably available". The obligation is conditioned on a reasonableness judgement nobody is assigned to make, and "should" states no obligation at all.	A	Minor
12.1.3	Although the definition of responsibilities in section 2 is otherwise sound, clause 2.5 requires role-relevant security responsibilities to be "included in job descriptions or equivalent	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	documented role descriptions" and names neither an owner nor a date for doing it. That element remains a promise.		
12.10.4	Incident-response training is required, with its frequency routed to a targeted risk analysis that does not yet exist, and no interim frequency is stated. Clause 11.4 therefore commits the organisation to no testable interval.	A	Minor
12.6.3	Clause 9.1 sets a stronger commitment than the sub-requirement, with documented exceptions and a defined completion date for anyone short of 100%. It names no owner for tracking beyond "Managers shall follow up", and no escalation point.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	
8.2.4 Additions, deletions and changes to IDs authorised and	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
limited to approved privileges			
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Partially addressed	1	Clause 4.6 is headed with 8.3.1 but states only "Authentication factors shall be protected as confidential security credentials" and then addresses passwords. The obligation that all user and administrator access is authenticated by a permitted factor is never stated.
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Largely addressed	2	Clause 4.6: "they shall contain alphabetic and numeric characters where required by PCI DSS". The composition

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			parameter is made conditional on an unstated determination; the twelve-character minimum is stated without qualification.
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Largely addressed	2	Clause 4.6: "Physical and logical tokens, certificates and other authentication factors assigned to individuals shall not be shared." The second element, that physical or logical controls ensure only the intended user can use the factor, is absent.
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
application account passwords protected and changed periodically			

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	Yes, on the written instrument. It is the most complete of the set, and the one that reads as though the organisation was in front of its author and not only the standard. The first challenge is that the policy requires a great many artefacts which do not exist, the incident response plan, the cryptographic inventory, the third-party register, the targeted risk analyses, the responsibility matrix, the access-control matrix, and sets no date and no owner for producing any of them. Clause 13.3's compliance calendar is the only scheduling mechanism in the document, and it is itself unpopulated. An assessor would accept the policy and then ask for the register, and on when the register appears the policy is silent. Second, 12.6.2. The annual review of the awareness programme is simply not there, in a document which states almost everything else twice.
Anything that reads as compliant on the surface but would not hold.	Clause 10.2. Deferring non-compliant supplier contracts to "renewal or sooner according to risk" reads as a step towards remediation and functions as none, since it carries no backstop, no owner and no risk threshold. 11 suppliers touch the environment and none is under a compliant agreement. Clause 4.6's "alphabetic and numeric characters where required by PCI DSS", and 4.8's "all applicable non-console access into the CDE". Both read as full statements of the requirement, and both hand the scope

Question	Response
	decision to somebody outside the policy. Clause 5.2's "where technically feasible" on log forwarding, in a document which elsewhere names the order-management log as the known exception.
Any requirement or sub-requirement missed, misstated or invented.	Nothing invented, and no sub-requirement number misattributed. Not addressed: 12.6.2. Stated too weakly, 5 of them. Clause 4.6 cites 8.3.1 and never states its obligation. 8.3.11 is missing the control that ensures only the intended user can use the factor. 8.4.2 is hedged with "applicable". 12.8.2 is missing the requirement to maintain agreements with all relevant providers, and 7.2.5.1 is missing both the addressing of inappropriate access and the management acknowledgement.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Yes. This is the one of the set which could be adopted with no amendment and then enforced, since it permits an on-call rota in place of an operations centre, automated first-stage log review, manual de-provisioning against a recorded completion, and controlled spreadsheets where a governance platform might have been demanded, each of which is where a function of 2 people actually sits. No single control carries the load. The calendar does: 6-monthly access reviews, 4 targeted risk analyses, annual cryptographic and technology reviews, annual supplier monitoring, annual scope validation, annual incident-response test, annual policy and training review. At this size that is achievable only where it is scheduled and owned, and the policy asks for the calendar without populating it.
Anything else worth recording.	The document writes the current state of the environment into its own text, the 3 legacy project groups, the 10-character minimum, the 78% completion rate, the February 2026 penetration-test findings. That is useful for remediation, and it dates the policy, because each of those clauses becomes wrong the moment it is acted on

Question	Response
	and nothing in section 15 retires them at review. The policy also carries substantial material outside Requirements 7, 8, 10 and 12, at sections 12 and 13. Only the 4 areas have been scored here. The additional material is no defect in itself, although it enlarges what 2 people must keep current.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Principal Security Consultant
Years of experience with PCI DSS	8 years
Currently or formerly a Qualified Security Assessor	Former QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	25	45
Second, Section D.9	46	90	90	75	72

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P2a

Date completed: 22 Aug 2026

Reviewer identifier: R1 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	93	Against the 9 applicable sub-requirements the extract reproduces for Requirement 7: 8 fully addressed, none largely addressed, 1 partially addressed (7.1.2), none unaddressed. 25 of 27 points, $100 \times 25 / 27 = 92.6$, rounded once to 93.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited and no defect of the 4 kinds arising. The section reproduces the requirement text closely, every sub-requirement number resolves to the obligation beside it, and the 6-month interval and the least-privilege wording are the version 4.0.1 ones.
Proportionality and scope fit	60	Entered at the midpoint of the 41 to 60 band and moved up twice. No control in the section assumes a resource or a system the scenario does not state, and nothing is disproportionate to a merchant of this size, every control being the standard's own. Nothing carries it towards the band above, because no scope statement specific to this organisation appears anywhere in the section, and because 2.6 describes controls over "repositories of stored cardholder data" as operating, in an environment where no primary account number rests on a NorthPay system and the policy nowhere discloses that.
Enforceability and clarity	50	The 6-month interval is numerical and the 4 review elements at 2.4 are enumerated, so that much is testable,

Criterion	Score, 0 to 100	Evidence or comment
		which lifts the entry 1 step off the midpoint of the 41 to 60 band. It comes down again, the whole section being written in the present indicative as a description of an existing state, so that nobody is required to do anything, and the approver is "authorised personnel" whilst the acknowledger is "management", neither of them identified.
Requirement-area score	77	$(93 \times 0.35) + (90 \times 0.25) + (60 \times 0.20) + (50 \times 0.20) = 32.55 + 22.5 + 12 + 10 = 77.05$, rounded once to 77.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.2	Clause 2.1.2 states that "Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood". The document contains no roles section and names nobody beyond the owner and the approver on the cover. Where the sub-requirement asks this instrument to make the assignment, no assignment is made.	A	Major
7.1.1	The clause reproduces the requirement as a statement of fact, in the present indicative. "All security policies and operational procedures identified in Requirement 7 are documented, kept up to date, in use, and known to all affected parties" imposes no obligation and names no action.	A	Minor
7.2.3	"Required privileges are approved by authorised personnel before access is granted". Who holds that authority is nowhere stated, so whether any given approval was validly given is not testable.	A	Minor
7.2.4	The 6-monthly review carries no owner and no record requirement, and no escalation attaches to it. "Management acknowledges that access remains	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	appropriate" identifies no manager and requires no evidence that the acknowledgement was given.		
7.2.6	Clause 2.6 describes controls over "repositories of stored cardholder data" as operating. No such repository exists on NorthPay systems, and the policy nowhere discloses that, so the clause protects nothing and the scope position is left to inference.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	97	Checklist result at Section D.13.5: 70 of 72 points, $100 \times 70 / 72 = 97.2$, rounded once to 97. That is 23 fully addressed, none largely addressed, 1 partially addressed (8.1.2) and none unaddressed. The figure sits far above what the section is worth on reading, and both stand. Every obligation is present because the section reproduces the requirement text, and coverage does not weigh the fact that none of it is imposed on anyone.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited and no defect of the 4 kinds. 10 attempts, 30 minutes, 12 characters with the 8-character fallback, 4 previous passwords, 90 days and 15 minutes are all the version 4.0.1 figures, and each sits under the correct sub-requirement number.
Proportionality and scope fit	65	Entered at the midpoint of the 61 to 80 band and moved down once. Every control in the section is operable through the single federated identity

Criterion	Score, 0 to 100	Evidence or comment
		provider the scenario states exists, so nothing here is beyond a function of 2 people. It moves down, and reaches no further, because the section contains no scope statement at all: 3.2.1 speaks of "cardholder data" generically, and nothing distinguishes this environment, in which no primary account number rests on a NorthPay system, from any other merchant's.
Enforceability and clarity	55	Every authentication parameter is numerical and would test directly against a configuration, which carries the entry 1 step above the midpoint of the 41 to 60 band. It reaches no higher, because not one clause in the section names a person, the section being a description of controls said to be in force, with no owner, no cadence for reviewing them and no consequence attached to any of them.
Requirement-area score	80	$(97 \times 0.35) + (90 \times 0.25) + (65 \times 0.20) + (55 \times 0.20) = 33.95 + 22.5 + 13 + 11 = 80.45$, rounded once to 80.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.1.2	Clause 3.1.2 asserts that roles and responsibilities for Requirement 8 activities "are documented, assigned, and understood", whilst the document assigns none. The defect is the one recorded at 7.1.2, and it recurs at 10.1.2 and 12.1.3.	A	Major
8.4.2	Clause 3.4.2 states "MFA is implemented for all non-console access into the CDE" as an existing fact, where multi-factor authentication is enforced on the cloud console and the collaboration suite alone. No obligation to extend it appears in the policy, and neither an owner nor a date, so nothing is given for the organisation to remediate against.	T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.2.8	Clause 3.2.7 states the 15-minute re-authentication rule as fact. Sessions on the order-management platform do not time out whilst the browser tab remains open, and nothing in the policy requires that to change.	T	Minor
8.3.6	Clause 3.3.5 states the 12-character minimum as fact, where the identity provider enforces 10. No clause requires the setting to be raised, and no system is named as bound.	T	Minor
8.6.2	The prohibition on hard-coded credentials is reproduced as a statement of the current position. Deployment credentials are held as repository secrets, and that arrangement is neither addressed nor required to be assessed.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	93	Against the 9 applicable sub-requirements the extract reproduces for Requirement 10: 8 fully addressed, none largely addressed, 1 partially addressed (10.1.2), none unaddressed. 25 of 27 points, $100 \times 25 / 27 = 92.6$, rounded once to 93.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited and nothing arising across the 4 defect kinds. 12 months with 3 immediately available is the version 4.0.1 figure, the 4 daily-review categories are reproduced correctly, and the 7 response elements at 4.5.1 match 10.7.3 exactly.
Proportionality and scope fit	60	Entered at the midpoint of the 61 to 80 band and moved down twice. The daily review is stated with no rota and no delegation, and with no allowance for an automated first stage, which a security function of 2, 1 of them working 3 days

Criterion	Score, 0 to 100	Evidence or comment
		a week, cannot sustain across weekends and holidays. Then 12-month retention is stated as an existing state, where the searchable period is 90 days with no archive configured and no clause requires the gap to be closed. No scope statement specific to this environment appears anywhere in the section.
Enforceability and clarity	55	Moved up 1 step from the midpoint of the 41 to 60 band. The intervals are numerical and the 7 failure-response steps are enumerated, so those are testable in form. Nothing carries it towards the band above, because no clause names a reviewer, a retainer or a responder, and "critical system components" and "critical security control systems" are left undefined for this environment.
Requirement-area score	78	$(93 \times 0.35) + (90 \times 0.25) + (60 \times 0.20) + (55 \times 0.20) = 32.55 + 22.5 + 12 + 11 = 78.05$, rounded once to 78.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.1.2	Clause 4.1.2 asserts that responsibilities for Requirement 10 activities "are documented, assigned, and understood". Nobody is named as accountable for logging or for the daily review, and nobody is named as responding to a control failure.	A	Major
10.5.1	Clause 4.4.1 states 12-month retention with 3 months immediately available as the current position. The platform retains 90 days of searchable logs, older logs are deleted or overwritten, and no archive exists. No clause requires an archive or names an owner, and no date is set.	T	Minor
10.4.1	The daily review is stated with no reviewer, no rota, no automated first stage and no record requirement, whilst the only alerting route in the	A, T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	environment is a shared mailbox watched 08:00 to 18:00 on working days, which the policy neither names nor addresses.		
10.4.3	"Exceptions and anomalies identified during the review process are addressed." No owner, no timescale, no record of the disposition and no link to incident response.	A	Minor
10.7.3	Although the 7 response steps are reproduced faithfully, "critical security control systems" is never defined for this environment and no responder is named, so both the trigger and the actor for the clause are undetermined.	T	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	Against the 30 applicable sub-requirements the extract reproduces for Requirement 12: 28 fully addressed, none largely addressed, 2 partially addressed (12.1.3 and 12.1.4), none unaddressed. 86 of 90 points, $100 \times 86 / 90 = 95.6$, rounded once to 96.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited and no defect of the 4 kinds. The 12-month intervals are the version 4.0.1 ones, the targeted risk analysis elements at 5.3.1 and the customized-approach elements at 5.3.2 are reproduced correctly, and the payment-page change-and-tamper mechanism is stated as a live requirement, which is right for an assessment in 2026.
Proportionality and scope fit	60	Entered at the midpoint of the 61 to 80 band and moved down twice. Clause 5.1.4 reproduces the requirement to assign information security responsibility to a Chief Information Security Officer or other knowledgeable executive, and then assigns it to nobody, in an

Criterion	Score, 0 to 100	Evidence or comment
		organisation which has no such officer and where ownership of the programme has never been written down, whilst 5.8.3 states 24/7 designated responders as an existing fact where no incident-response roles have been assigned at all. No scope statement specific to this environment appears anywhere in the section.
Enforceability and clarity	50	The cover names an owner and an approver, and 6 states an annual review cadence together with an annual acknowledgement obligation, which are the only 2 obligations in the document expressed as obligations at all. That lifts the entry 1 step off the midpoint of the 41 to 60 band, and 1 step back down follows. Sections 5.1 to 5.8 are written throughout as descriptions of an existing state, so the whole annual calendar of reviews, analyses, monitoring, training and testing rests on nobody.
Requirement-area score	78	$(96 \times 0.35) + (90 \times 0.25) + (60 \times 0.20) + (50 \times 0.20) = 33.6 + 22.5 + 12 + 10 = 78.1$, rounded once to 78.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.1.3	Clause 5.1.3 states that "The security policy clearly defines information security roles and responsibilities for all personnel". This policy defines none. The statement is contradicted by the document which makes it, and an assessor reading the 2 together would record the sub-requirement as not in place.	A	Major
12.1.4	Clause 5.1.4 reproduces the requirement to assign responsibility for information security to a Chief Information Security Officer or other knowledgeable member of executive management, and assigns it to nobody. NorthPay has no such officer. The cover	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	names the Chief Technology Officer as approver of the document, which is a different thing from that assignment.		
12.10.1	Clause 5.8.1 states that "An incident response plan exists and is ready to be activated" and then lists what it contains. No clause requires a plan to be written, and none names an author or sets a date, and since no security incident response plan exists, the control is asserted where it needed to be created.	A	Major
12.3.1	Although the 6 elements of the targeted risk analysis are reproduced, no owner and no date is set for performing one, and 4 other clauses (7.2.5.1, 8.6.3, 10.4.2.1 and 12.10.4.1) take their frequency from an analysis nobody is required to produce.	A	Minor
12.8.1	The supplier list is stated as maintained, whilst no owner and no review interval attaches to it, and the suppliers already touching the environment are nowhere referred to. The same applies to the written agreements at 5.7.2 and the responsibility matrix at 5.7.5.	A	Minor
12.6.3	Training on hire and every 12 months, with annual acknowledgement, is stated as happening. No owner, no completion tracking, no escalation and no consequence, and the shortfall in the current completion rate is not addressed.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	
8.1.2 Roles and responsibilities documented, assigned and understood	Partially addressed	1	Clause 3.1.2: "Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood." The topic is stated in the standard's own words, but the policy assigns no role to anyone and names nobody, so there is nothing an assessor could test.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	
8.3.4 Invalid authentication attempts limited by logout	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	It would pass a documentation review which asked only whether each sub-requirement is mentioned. It would not survive an assessor who asked the next question. The first challenge is that what the document amounts to is the requirement

Question	Response
	text renumbered. Every clause sits in the present indicative, so nothing is imposed on anyone. Clause 2.4.1 does not say the review shall be performed, it says the review is performed. Ask who carries out the 6-monthly access review, who reads the logs each day, who holds the supplier register and who writes the incident response plan, and the document has no answer, because it names nobody beyond the owner and the approver on the cover.
Anything that reads as compliant on the surface but would not hold.	Almost all of sections 3, 4 and 5. "MFA is implemented for all non-console access into the CDE." "Audit log history is retained for at least 12 months." "If a user session has been idle for more than 15 minutes, the user is required to re-authenticate." "An incident response plan exists and is ready to be activated." Each is written as a statement of the current position, and each is contradicted by the environment as described. A policy which describes a state where it needed to require one gives the organisation nothing to remediate against, and gives the assessor a document wrong on its face. Clause 5.1.3 is the sharpest instance. It asserts that the policy clearly defines roles and responsibilities for all personnel, in a policy which defines none.
Any requirement or sub-requirement missed, misstated or invented.	Nothing invented, nothing misattributed, no superseded parameter. Every applicable sub-requirement in the extract appears. Understated, and understated identically each time: 7.1.2, 8.1.2, 10.1.2, 12.1.3 and 12.1.4. Those 5 ask for roles and responsibilities to be documented and assigned, and they are the 5 this document structurally cannot satisfy, because it contains no roles.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Adopt, yes, trivially, since it is already written. Enforce, no, because there is nothing in it to enforce. Every recurring activity lacks an owner and every control lacks a consequence. The document also nowhere acknowledges

Question	Response
	the organisation it is for. Neither the security function of 2 people nor the federation of access through a single identity provider is stated anywhere, and the fact that no primary account number rests on its systems is not disclosed. 2 people could run this requirement set. Not from this document.
Anything else worth recording.	There is no NorthPay in it. Change the name on the cover and it serves any merchant unaltered. That is why the 4 criteria pull so far apart here. Coverage is high because every obligation appears in the standard's own words, and enforceability is low because none of those obligations is anybody's. The instrument is measuring 2 different things, and the gap between them is the finding.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Principal Security Consultant
Years of experience with PCI DSS	8 years
Currently or formerly a Qualified Security Assessor	Former QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	25	45
Second, Section D.9	46	90	90	75	72

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P2b

Date completed: 22 Aug 2026

Reviewer identifier: R1 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	89	Of the 9 applicable sub-requirements the extract reproduces for Requirement 7, 6 are fully addressed and 3 largely addressed (7.1.1, 7.2.1, 7.2.5.1), with none partial and none unaddressed. 24 of 27 points, $100 \times 24 / 27 = 88.9$, rounded once to 89.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited. The 6-month interval is the version 4.0.1 one, the application-account review frequency is routed through 12.3.1, and nothing in section 3 asserts an obligation the standard does not contain. Clause 3.5's extension to "data that could lead to" cardholder data is stricter than the standard and is not wrong, so it is recorded as a clarity finding.
Proportionality and scope fit	95	1 step up from the midpoint of the 81 to 100 band. Section 2 assigns access-control duties to roles which exist in this organisation, the Information Security Manager, the line managers, the compliance analyst working 3 days a week, in place of an abstract function, and 3.2 routes approval to a named role with the CTO reserved for privileged access. Clause 3.6 states the data position exactly: only the last 4 digits are held, alongside personal data.
Enforceability and clarity	75	2 steps up from the midpoint of the 61 to 80 band and 1 down. The approver is named at 3.2, the Information Security Manager, or the CTO where the role is

Criterion	Score, 0 to 100	Evidence or comment
		privileged, and section 2 gives each access-control activity a holder, the line managers amongst them, who confirm continued need at review. Against that, the application-account review interval at 3.4 depends on a targeted risk analysis which 6.3 requires and neither dates nor owns, so that clause states no testable frequency.
Requirement-area score	88	$(89 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (75 \times 0.20) = 31.15 + 22.5 + 19 + 15 = 87.65$, rounded once to 88.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.1	No clause requires the security policies and operational procedures supporting Requirement 7 to be documented, kept up to date, in use and known to all affected parties. The document control block covers this policy alone, and section 8 lists the related documents whilst imposing nothing about them.	A	Minor
7.2.1	No access control model is defined. Clause 3.1 states least privilege and job classification as principles, whilst the groups through which access is actually granted go undescribed, and no role or group structure appears anywhere in the policy.	A	Minor
7.2.5.1	Clause 3.4 requires the periodic review and the management acknowledgement, and omits the element requiring inappropriate access found by the review to be addressed. That element is stated for user accounts at 3.3 and dropped here.	A	Minor
7.2.6	Clause 3.5 extends the control to "any repository that holds cardholder data (or data that could lead to it)". The second category is not defined, so the boundary of the control is not testable, and on the scenario the clause could be read to cover the order-management	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	database.		
7.2.4	Although the 6-monthly review names its participants, no single holder of completion is named, and neither escalation nor consequence is stated where a review is not carried out timely.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	88	Checklist result at Section D.13.5: 63 of 72 points, $100 \times 63 / 72 = 87.5$, rounded once to 88. That is 17 fully addressed, 6 largely addressed, none partially addressed and 1 unaddressed (8.3.3).
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited. 12 characters, 10 attempts, 30 minutes, 4 previous passwords, 90 days and 15 minutes all match version 4.0.1. The weakening of 8.2.5 at 4.3 is a coverage finding and not an accuracy one, since nothing asserted there is false about the standard.
Proportionality and scope fit	95	1 step up from the midpoint of the 81 to 100 band. Clause 4.9 names the current position, MFA enforced on the cloud console and the collaboration suite, and then names the specific systems it is extended to, the order-management platform, the PSP merchant portal and the helpdesk platform. That is an instruction a function of 2 can act on, using the single identity provider the scenario states federates all of them.
Enforceability and clarity	65	Every authentication parameter at 4.7 and 4.8 is numerical and testable against a configuration, which lifts the

Criterion	Score, 0 to 100	Evidence or comment
		entry 1 step above the midpoint of the 61 to 80 band. 2 steps come back down, the exception routes at 4.1 and 4.11 resting on approval "by management" with no approver named and no maximum duration, and the extension of MFA at 4.9, together with the verification duties implied by 4.2, carrying no owner and no date.
Requirement-area score	85	$(88 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (65 \times 0.20) = 30.8 + 22.5 + 19 + 13 = 85.3$, rounded once to 85.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.3.3	Absent. No clause requires a user's identity to be verified before an authentication factor is modified. Clause 4.2 requires prior documented approval for changes to authentication factors, which discharges 8.2.4 and is a different control, and the service-desk reset path is left unaddressed.	T	Major
8.2.5	"Access for terminated users is revoked immediately on the last working day (or sooner if the circumstances require)." Immediately and on the last working day are 2 different commitments, and the sentence makes the weaker of them the default, where the standard requires immediate revocation.	T	Minor
8.6.1	Clause 4.11 omits 2 elements, the documented business justification for interactive use, and the confirmation of the individual user's identity before access to the account is granted.	T	Minor
8.6.3	Although clause 4.11 requires periodic and on-suspicion changes, the complexity element is omitted, that the credential is constructed with complexity appropriate to how often it is changed.	T	Minor
8.3.8	Clause 4.12 covers selection, protection, reuse and reporting, and	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	omits the instruction to change a password or passphrase where compromise is suspected or known. Nothing requires the guidance to exist as a documented and communicated artefact either, users being simply "given" it.		
8.2.2	Clause 4.1 omits confirmation of the individual's identity before access to a shared account is granted, and names no approver beyond "management", so the exception is not testable against any authority.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	93	Of the 9 applicable sub-requirements the extract reproduces for Requirement 10, 7 are fully addressed and 2 largely addressed (10.1.1, 10.7.3), with none partial and none unaddressed. 25 of 27 points, $100 \times 25 / 27 = 92.6$, rounded once to 93.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited and no defect of the 4 kinds appearing. 12 months with 3 immediately available is the version 4.0.1 figure and the 4 daily-review categories are stated correctly. The parenthetical acknowledgement that current retention is 90 days is accurate, and no misstatement.
Proportionality and scope fit	90	1 step up from the midpoint of the 81 to 100 band and 1 down. Clause 5.6 names the actual gap, 90 days of searchable retention with no archive, and states the remedy, and the section closes with a dated obligation to define log retention schedules within 3 months of adoption. Downwards: the daily review at 5.3 is stated with no rota and no delegation, and no allowance for an automated first

Criterion	Score, 0 to 100	Evidence or comment
		stage, which a security function of 2 cannot sustain across weekends.
Enforceability and clarity	70	2 steps up from the midpoint of the 61 to 80 band, and 2 down. Section 2 makes the Information Security Manager the named owner of logging and monitoring, and the 3-month deadline for retention schedules is one of very few dated commitments in any of these documents. Downwards: the daily review names no reviewer and requires no record of having occurred, and "will be extended or supplemented by offline archive" at 5.6 is a parenthetical undertaking carrying no owner and no date.
Requirement-area score	87	$(93 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (70 \times 0.20) = 32.55 + 22.5 + 18 + 14 = 87.05$, rounded once to 87.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.7.3	Clause 5.7 omits 1 element, in that the cause must be recorded and preventive measures implemented, whilst the required remediation is not required to be documented.	T	Minor
10.1.1	No clause requires the logging and monitoring procedures themselves to be documented, kept current, in use and known to affected parties. Section 8 lists them as related documents and imposes nothing on them.	A	Minor
10.4.1	No named reviewer attaches to the daily review, no record of it is required, and no allowance is made for an automated first stage, in an environment whose only alerting route is a shared mailbox watched 08:00 to 18:00 on working days, a route the policy nowhere names.	A, T	Minor
10.5.1	The undertaking to close the retention gap sits inside a parenthesis, "Current SIEM retention of 90 days will be	T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	extended or supplemented by offline archive to meet this requirement", carrying no owner and no date, in a document which sets a 3-month deadline 2 paragraphs later.		
10.3.1	Although read access is limited to those with a job-related need, nobody owns the entitlement list, and it is not drawn into the 6-monthly access review at 3.3.	T	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	80	Of the 30 applicable sub-requirements the extract reproduces for Requirement 12, 21 are fully addressed, 4 largely addressed (12.2.1, 12.3.1, 12.5.2, 12.10.7), 1 partially addressed (12.10.5) and 4 not addressed (12.3.2, 12.3.3, 12.3.4, 12.6.2). 72 of 90 points, $100 \times 72 / 90 = 80$.
Accuracy	90	Midpoint of the 81 to 100 band, no factor cited. Sub-requirement numbers resolve, the 12-month intervals match version 4.0.1, and 6.3 lists the 4 dependent clauses correctly. The statement at 6.2 that personal-device restriction is enforced by conditional access is false about the environment and not about the standard, so it is recorded under the next criterion and as a finding.
Proportionality and scope fit	85	1 step up from the midpoint of the 81 to 100 band and 2 down. Section 2 maps every governance duty onto a role which exists, the compliance analyst working 3 days a week and the Head of Finance and Legal amongst them, and 1 states the no-PAN position correctly. Section 1 then calls the storefront, the checkout page, the order-management platform and the administrator access paths "the

Criterion	Score, 0 to 100	Evidence or comment
		CDE", where on the scenario those are systems connected to or impacting it, and the mislabel will misdirect the scope validation 6.4 requires. Clause 6.2 records the personal-device restriction as enforced by conditional-access policy where it is enforced by convention, so the obligation to build the control is removed by the document which should have imposed it.
Enforceability and clarity	75	2 steps up from the midpoint of the 61 to 80 band, 1 down. Every governance activity in section 2 has a named holder, and section 7 names the reviewer and the approver with a cadence, whilst the document control block carries owner, approver, review cycle and next review date. Against that, 6.7 and 6.8 are written as bullet lists of contents, with no owner attached to any single obligation and no interval set for maintaining the supplier register.
Requirement-area score	83	$(80 \times 0.35) + (90 \times 0.25) + (85 \times 0.20) + (75 \times 0.20) = 28 + 22.5 + 17 + 15 = 82.5$, rounded once to 83.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.3.3	Absent. No inventory of cipher suites and protocols, no annual review of one, no monitoring of industry trends and no plan for anticipated cryptographic change. On the scenario no such inventory exists and certificate expiry is tracked on 1 engineer's spreadsheet, which is the gap the sub-requirement exists to close.	A, T	Major
12.3.4	Absent. No annual review of hardware and software technologies, no analysis of continued vendor support, no end-of-life tracking and no remediation plan for outdated technology approved by senior management.	A	Major
12.6.2	Absent. Nothing requires the security	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	awareness programme to be reviewed at least every 12 months, or updated against new threats. Clause 6.5 sets the training frequency and the content, and says nothing about the programme itself.		
12.3.2	Absent. The customized approach, and the targeted risk analysis it requires, go unmentioned. The defined approach is nowhere expressly adopted, and no conditions are set for departing from it.	A	Major
12.10.5	Clause 6.8 states only that "The plan includes monitoring and response to alerts from security systems", and none of the 5 categories is named. Where NorthPay serves its own checkout page, the change-and-tamper-detection mechanism for payment pages is the omission which matters most.	A, T	Major
12.10.7	Clause 6.8 omits the determination of whether sensitive authentication data is stored alongside any PAN found where it is not expected.	A	Minor
12.2.1	"This restriction is enforced by conditional-access policy." It is enforced by convention, and recording a control as already in force removes the obligation to build it. The explicit approval by authorised parties, and the list of approved products, are also not stated as elements of the acceptable-use rules.	T, A	Minor
12.5.2	Clause 6.4's scope validation omits the updating of data-flow diagrams, and the final confirmation that all identified flows, data, components, segmentation controls and third-party connections are included in scope.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total}$

points ÷ 72. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Largely addressed	2	No clause requires the operational procedures supporting Requirement 8 to be documented, current, in use and known. The document control block covers this policy only: "published on the company intranet and is issued to all staff and relevant suppliers".
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Largely addressed	2	Clause 4.1: shared accounts "forbidden except in documented, time-limited exceptional circumstances that are approved by management and that still allow actions to be attributed to an individual". Confirmation of the individual's identity before access is granted is absent, and no approver is named.
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	
8.2.5 Access for terminated users revoked immediately	Largely addressed	2	Clause 4.3: "Access for terminated users is revoked immediately on the last working day (or sooner if the circumstances require)." The last working day is weaker than immediately and is made

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			the default.
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	
8.3.3 Identity verified before an authentication factor is changed	Not addressed	0	absent
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Largely addressed	2	Clause 4.12 covers selection, protection, non-reuse and reporting, but omits the instruction to change a password where compromise is suspected or known, and does not require the guidance to be documented and communicated as such.
8.3.9 Password changed at least	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
every 90 days, or dynamic access analysis			
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	
8.6.1 Interactive login by system or application accounts controlled	Largely addressed	2	Clause 4.11: interactive use is "treated as exceptional, time-limited, approved and attributable to an individual". Documented business justification, and confirmation of individual identity before access, are absent.
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and application account passwords protected and changed periodically	Largely addressed	2	Clause 4.11: passwords "changed periodically according to the targeted risk analysis, or immediately on suspicion of compromise". The complexity element, appropriate to the change frequency, is absent.

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real	On Requirements 7, 8 and 10, yes. On

Question	Response
PCI DSS assessment, and what would you challenge first?	Requirement 12, no. 4 applicable sub-requirements are absent outright, 12.3.2, 12.3.3, 12.3.4 and 12.6.2, and 12.10.5 amounts to 1 generic sentence where 5 categories of alert are required. The first challenge is the missing cryptographic inventory and technology review. The organisation holds no inventory of algorithms, protocol versions, certificates, key locations or key holders, and tracks certificate expiry on 1 engineer's spreadsheet, which is the exposure 12.3.3 and 12.3.4 exist to address, and neither of them is mentioned.
Anything that reads as compliant on the surface but would not hold.	Clause 6.2: "This restriction is enforced by conditional-access policy." It is enforced by convention. A policy which records a control as already in force removes the requirement to build it, and this is the one control the organisation most needs built. Clause 4.3: "revoked immediately on the last working day". It reads as compliance with 8.2.5 and is not, the 2 halves of the sentence contradicting each other, with the weaker half governing. Clause 5.6's parenthesis on log retention. An undertaking with no owner and no date, in a document which manages a 3-month deadline 2 paragraphs later.
Any requirement or sub-requirement missed, misstated or invented.	Absent: 12.3.2, 12.3.3, 12.3.4, 12.6.2 and 8.3.3. Understated: 12.10.5, 12.10.7, 12.2.1, 12.5.2, 8.6.1, 8.6.3, 8.3.8, 8.2.2, 7.2.1, 7.2.5.1 and 10.7.3. Nothing invented, and every sub-requirement number cited resolves to the obligation beside it. One mischaracterisation is worth recording. Clause 1 calls the storefront, the checkout page, the order-management platform and the administrator access paths "the CDE". On the scenario those are systems connected to or impacting the CDE, which holds no primary account number. The error makes the policy stricter where it might have made it weaker, which does not save

Question	Response
	it, since the description is wrong and it will misdirect the annual scope validation the policy itself requires.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Yes, and more comfortably than any other document in this set. Section 2 assigns every activity to a person who exists, the compliance analyst working 3 days a week and the Head of Finance and Legal amongst them. Clause 6.5 sets a completion target and names the current shortfall. Section 5 sets a dated obligation. It is short enough that the 61 people it applies to might actually read it. The price is completeness. 4 Requirement 12 sub-requirements are not in the document at all.
Anything else worth recording.	The trade this document makes is legibility against coverage, and at this size the judgement behind it is defensible. The 4 sub-requirements traded away are the wrong ones. A cryptographic inventory and a technology review are a page of writing each, and both gaps stand open in the environment today, whilst the awareness programme's annual review is 1 sentence. Nothing was gained by omitting them.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Principal Security Consultant
Years of experience with PCI DSS	8 years
Currently or formerly a Qualified Security Assessor	Former QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	11	90	70	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P1a

Date completed: 22 Aug 2026

Reviewer identifier: R2 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	9 applicable sub-requirements in the extract for Requirement 7. I make it 8 fully addressed and 1 largely with nothing partial and nothing absent. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96. Only 7.1.2 falls short.
Accuracy	90	Straight midpoint of 81 to 100 and nothing moved it either way — I found none of the four defect kinds in this area. The citations at 2.1 to 2.5 land on the obligations they carry. I checked the six-month interval and the least-privilege wording against version 4.0.1 and they are the current figures. Nothing is invented.
Proportionality and scope fit	90	Midpoint again at 81 to 100. A two-person function can run six-monthly reviews and approve before provisioning and that is the test I applied. Section 2.1 clears out groups left behind by finished projects which is the estate as it stands, and stored cardholder data is handled conditionally at 2.5, while I read 1.2 as right that a connected component stays in scope even with no primary account number on it.
Enforceability and clarity	70	70 is the midpoint of 61 to 80 and I moved once each way. Up for the six-month cadence at 2.3 with its four review elements and the management acknowledgement, all of which an assessor can test. Down because every obligation in section 2 sits on “NorthPay” and the approver is only “authorized

Criterion	Score, 0 to 100	Evidence or comment
		personnel". Net 70. At a management review I couldn't tell you who runs the review.
Requirement-area score	88	$(96 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (70 \times 0.20) = 33.6 + 22.5 + 18 + 14 = 88.1$, rounded to 88.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.2	Nobody owns the six-monthly access review. Section 1.3 says specific operational responsibilities for access control "shall be documented, assigned and communicated" which pushes the assignment into a document that does not yet exist. Nothing addresses "understood" at all, so I have nothing to test.	A	Minor
7.2.3	The approver is "authorized personnel" (2.2). Who that is the policy never says, so neither I nor an assessor can test whether a given approval was valid.	A	Minor
7.2.4	"NorthPay" carries the review obligation at 2.3. No reviewer named. No form of management acknowledgement set out either.	A	Minor
7.2.6	Dormant as written. The control only bites if a repository of stored cardholder data exists "within scope" (2.5) and nothing puts anyone under a duty to go looking for one.	T, A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	From the checklist at D.13.5. 71 of 72 points, $100 \times 71 / 72 = 98.6$, rounded

Criterion	Score, 0 to 100	Evidence or comment
		once to 99. I have 23 sub-requirements fully addressed and 1 largely at 8.1.2 with nothing partial and nothing absent.
Accuracy	90	Band midpoint at 81 to 100 with nothing cited to move it. 12 characters, 10 attempts, 30 minutes, 15 minutes, 90 days and 4 previous passwords are the version 4.0.1 figures and not the older ones. I read the cross-reference to 12.3.1 at 3.12 as ordinary good practice so it doesn't count against accuracy.
Proportionality and scope fit	90	Midpoint of 81 to 100. Every control here runs through the identity provider the scenario says is already in place so capacity isn't my question. Section 3.8 lifts the 10-character minimum that's in force and 3.11 won't let multi-factor authentication stop at the AWS console and the collaboration suite, while 3.5 catches the session that stays authenticated for as long as a browser tab is open.
Enforceability and clarity	75	Start at 70 and up twice, because 1.3 names a policy owner and an executive owner and the exception route at 3.2 carries management approval and a time limit and pins the account to a named individual. Down once. Operational responsibilities for identity and authentication are still only promised. Net 75. I'd want a name against them.
Requirement-area score	90	$(99 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (75 \times 0.20) = 34.65 + 22.5 + 18 + 15 = 90.15$, rounded to 90.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.1.2	The 7.1.2 problem again. Section 1.3 promises that responsibilities for identity management and authentication will be documented and assigned. Nothing is assigned in the policy itself so I am back at the same	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	gap.		
8.2.2	“management” approves the exception at 3.2. No role behind the word. No ceiling on duration beyond “the time required”.	A	Minor
8.3.6	Section 3.8 requires systems on a 10-character minimum to be changed “wherever the system supports it”. Nobody owns it and there’s no date on it. In practice the identity provider setting decides the outcome and that is the setting I would test.	T	Minor
8.4.2	Section 3.11 pushes multi-factor authentication past the AWS console and collaboration suite then sets no implementation date and names nobody. The order management platform still doesn’t have it. Nor does the merchant portal at the payment service provider or the helpdesk platform.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	9 applicable sub-requirements. 8 fully addressed and 1 largely at 10.1.2 with none partial and none absent. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96.
Accuracy	90	Midpoint of 81 to 100 with nothing to move it. 12-month retention with 3 months immediately available is the version 4.0.1 position and the 10.4.2.1 cross-reference to 12.3.1 holds. I can’t find an invented obligation anywhere in the area.
Proportionality and scope fit	85	90 and down one step. Weekends are the problem. Section 4.3 wants the review done “every day” and “irrespective of normal office hours” with no rota and no on-call route, while the alerts land in a mailbox watched

Criterion	Score, 0 to 100	Evidence or comment
		08:00 to 18:00 on working days. Retention and restricted read access and anomaly handling all sit inside what 2 people can carry and none of that troubles me.
Enforceability and clarity	70	70 with one step each way. Up for the numeric cadences, which are daily review and 12 months of retention with the most recent 3 immediately available. Down because no clause names a reviewer and 4.4 drops the software-as-a-service administrator log into “the applicable review arrangements” without saying whose those are. Net 70.
Requirement-area score	87	$(96 \times 0.35) + (90 \times 0.25) + (85 \times 0.20) + (70 \times 0.20) = 33.6 + 22.5 + 17 + 14 = 87.1$, rounded to 87.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.4.1	Section 4.3 requires the review every day “irrespective of normal office hours”. No reviewer is named. There’s no rota either, and nothing says how an out-of-hours event reaches anyone. This is the clause I’d challenge first in this policy.	A, T	Minor
10.4.2	The SaaS administrator activity log has to be “included in the applicable review arrangements” (4.4). Whose arrangements we’re not told. And a log that never reaches the security information and event management platform has no obvious way of reaching a reviewer either.	T, A	Minor
10.5.1	Section 4.6 calls for archival beyond the 90-day searchable period. It doesn’t say where the archive lives or who builds it and no date attaches to the point at which a 12-month history exists.	T	Minor
10.1.2	Section 4.1 says responsibilities “shall be assigned and understood”. None is	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	assigned anywhere in the document.		

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	30 applicable sub-requirements with 29 fully addressed and 12.1.3 largely. Nothing partial and nothing absent. 89 of 90 points, $100 \times 89 / 90 = 98.9$, rounded once to 99.
Accuracy	90	Midpoint of 81 to 100 with nothing cited. The payment-page tamper-detection bullet is carried at 8.5 “in accordance with its PCI DSS applicability status” which I take as the right treatment. No Financial Conduct Authority obligation is asserted anywhere and none of the four defect kinds appears.
Proportionality and scope fit	85	90 and down one. We would not hold 2 people to 8.3 as it is written, with designated 24/7 responders and cover outside shared-mailbox hours and no rota and no deputy and no contact route behind any of it. Everywhere else the annual cadences and the register-based controls sit comfortably against a 61-person merchant and my judgment there is that they are fair.
Enforceability and clarity	70	70 with one step up and one down. Up because 1.3 names the Chief Technology Officer and the Information Security Manager while 9.2 sets an annual review cadence, and down because the third-party service provider register carries no owner and no date and neither do the targeted risk analyses or the 24/7 designation. Net 70.
Requirement-area score	88	$(99 \times 0.35) + (90 \times 0.25) + (85 \times 0.20) + (70 \times 0.20) = 34.65 + 22.5 + 17 + 14 = 88.15$, rounded to 88.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.10.3	An obligation this heavy has to name people. Section 8.3 asks for designated 24/7 responders and cover outside shared-mailbox hours, then supplies no rota, names no primary or backup and gives no contact route.	A	Minor
12.1.3	Section 1.3 pushes the definition of specific responsibilities into a later document. So the policy doesn't itself define information security roles for all personnel and I could not tell a member of staff what theirs is.	A	Minor
12.3.1	Section 5.3 sets out what a targeted risk analysis has to contain. No owner against it and no date. NorthPay holds none of them and nothing here moves anyone toward the first.	A	Minor
12.8.1	Section 7.1 requires the TPSP register. Nobody owns it and no review cadence attaches to it.	A	Minor
12.6.3	A repeat of the 78 per cent completion rate would breach no clause in here, because section 6.2 wants completion tracked and outstanding training chased while setting no threshold and naming nobody.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	
8.1.2 Roles and responsibilities	Largely	2	"Specific operational

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
documented, assigned and understood	addressed		responsibilities for ... identity management, authentication ... shall be documented, assigned and communicated” (1.3). The policy promises assignment rather than assigning, and does not address the responsibilities being understood.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	
8.6.2 No hard-coded passwords in scripts, configuration files	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
or code			
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	On paper, yes. Every applicable sub-requirement in all four areas is addressed and the parameters are right throughout. I'd go at section 8.3 first — the 24/7 designation — and section 4.3 with it, where the daily log review runs "irrespective of normal office hours". Both are stated at full strength and neither has a rota or a deputy or a named owner behind it. With 2 people and a mailbox watched 08:00 to 18:00 on working days we'd be signing up to something I couldn't evidence for a single weekend.
Anything that reads as compliant on the surface but would not hold.	Almost nothing lands on a person. The pattern throughout is "NorthPay shall", and section 1.3 promises that operational responsibilities "shall be documented, assigned and communicated" which is a plan to assign and is the sentence I expect an assessor to pull on first. The remediation clauses have the same hole in them. Section 3.8 raises the 10-character minimum "wherever the system supports it" while 4.6 wants archival sufficient for 12 months, and neither carries a date or a name. Read at speed it looks finished.
Any requirement or sub-requirement missed, misstated or invented.	Nothing invented and nothing misattributed. The numbering resolves throughout including the cross-references to 12.3.1 from Requirements 7, 8, 10 and 12, and the parameters are the version 4.0.1 figures. Coverage gaps sit at 7.1.2, 8.1.2, 10.1.2 and 12.1.3, and it's the same gap 4 times over

Question	Response
	because my reading of all four is that responsibilities have been handed to a document nobody has written.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Adopt, yes. Enforcing it as written needs an on-call rota and a decision about weekend log review. The rest of it — six-monthly access reviews, annual scope validation, the TPSP register, the awareness programme, the targeted risk analyses — makes a heavy year for a compliance analyst on 3 days a week. It's ordinary work though and I think it's sequenced sensibly.
Anything else worth recording.	The standard is what this was written against. NorthPay barely shows up in it. Where it does touch the estate it's sharp and I'd point among other things to the 10-character minimum, the 90-day SIEM retention, the browser-tab session and the legacy project groups. That happens 4 times in 12 pages. Policy-level score, the arithmetic mean of the four unrounded requirement-area scores, is 88.375, rounded to 88.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Head of IT and Security
Years of experience with PCI DSS	12 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	11	90	70	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P1b

Date completed: 22 Aug 2026

Reviewer identifier: R2 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	I scored the 9 applicable sub-requirements and got 8 full and 1 largely at 7.2.5.1 with no partials and nothing missing. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96.
Accuracy	90	Band midpoint and I found nothing to move it. Checking 3.1 to 3.6 against 7.1.1 through 7.2.6, the citations carry the obligations they claim. The 6-month interval is the version 4.0.1 figure. Nothing invented.
Proportionality and scope fit	90	Midpoint of 81 to 100. Section 3.3 names the 3 legacy groups left behind by the project that finished in 2025 while 3.6 says no repository of stored primary account number is intentionally maintained and holds the control open in case that changes. A named system owner per system is what 2.4 requires and it is workable across 61 staff. I see no capacity problem in any of it.
Enforceability and clarity	80	70 and up twice. Section 3.2 wants evidence of request and approval and implementation and it forbids self-approval of privileged access, while 3.4 names the Information Security Manager for completion tracking of the six-monthly review. It stays out of the band above because “separation between ordinary and privileged access where appropriate” (3.1) and the “material in-scope systems” boundary of the access-control matrix both land on whoever happens to be doing the review, and I

Criterion	Score, 0 to 100	Evidence or comment
		can't test a boundary somebody else draws.
Requirement-area score	90	$(96 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (80 \times 0.20) = 33.6 + 22.5 + 18 + 16 = 90.1$, rounded to 90.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.2.5.1	Section 3.5 sets the review frequency by targeted risk analysis and then drops 2 elements. I make them inappropriate application and system account access being addressed, and management acknowledging that the access remains appropriate.	A	Minor
7.2.1	"Separation between ordinary and privileged access where appropriate" (3.1). Appropriate when? No criterion is given and I would have to invent one.	A	Minor
7.2.4	The access-control matrix covers "material in-scope systems" (3.1). So whoever runs the six-monthly review decides what falls inside it, and I wouldn't want to be the one defending that boundary.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	94	Checklist at D.13.5 gives me 68 of 72 points, $100 \times 68 / 72 = 94.4$, rounded once to 94. 21 fully addressed, 2 largely at 8.3.6 and 8.3.9, 1 partially at 8.3.1 and none absent.
Accuracy	90	90 and nothing cited against it. Parameters match version 4.0.1 and the numbering resolves. The 2 weakenings

Criterion	Score, 0 to 100	Evidence or comment
		at 8.3.6 and 8.3.9 put real obligations in softer terms so I've taken them under coverage. Nothing asserted here is false.
Proportionality and scope fit	95	90 and up one, for 4.3. It accepts that removal of access from the software-as-a-service platforms is manual today and puts a completion record for each service on the responsible administrator and won't wait for automation to arrive, which is the kind of clause we can act on. Our 2-person function could run it this week.
Enforceability and clarity	80	70 and up twice. Real actors get named — HR, managers, system owners, the service desk and the Information Security Manager — and 4.6 is full of numeric parameters I can test. It stays under 81 because “where technically possible”, “where supported” and “where required by PCI DSS” keep coming back, and because 4.5 fixes the session that never times out without saying when.
Requirement-area score	90	$(94 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 32.9 + 22.5 + 19 + 16 = 90.4$, rounded to 90.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.3.1	The base obligation never appears. Section 4.6 opens on protecting authentication factors and goes straight into password parameters, and nowhere does this policy say that all user and administrator access is authenticated by one of the 3 permitted factor types.	T	Major
8.3.6	“They shall contain alphabetic and numeric characters where required by PCI DSS” (4.6). Both are required and there's no condition on it. The hedge invites a configuration weaker than the one we already run.	T	Minor
8.3.9	“NorthPay may remove unnecessary	T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	routine password expiry for accounts protected by MFA only where doing so remains consistent with the applicable PCI DSS authentication requirements” (4.6). That leaves whoever configures the identity provider to work out what the 90-day change still means.		
8.2.8	The order management platform doesn’t time out at all while the tab is open, which is a live problem for us. Section 4.5 requires non-conforming sessions to be “remediated or otherwise brought into compliance where the requirement applies”, with nobody named and no date.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	100	I have all 9 applicable sub-requirements fully addressed and nothing sitting below full. 27 of 27 points, 100.
Accuracy	90	Midpoint and no factor cited, because 12-month retention with 3 months immediately available is the version 4.0.1 position and I can’t fault the failure-response elements at 5.8 which track 10.7.3 with nothing added and nothing dropped.
Proportionality and scope fit	95	90 and up one, for 5.3. No staffed 24-hour operations centre is demanded of us. High-severity alerts have to be able to reach the designated on-call responder and a mailbox watched only in working hours can’t be the sole route. That’s the right answer for an organisation our size — and it’s the clause most policies of this kind get wrong.
Enforceability and clarity	80	70 and up twice. Section 5.1 makes the Information Security Manager accountable and puts named duties on engineering and on SaaS system

Criterion	Score, 0 to 100	Evidence or comment
		owners, while 5.5 fixes what goes into the review record as the event, the reviewer, the date, the conclusion and the action. It sits below 81 because “where technically feasible” governs central log forwarding and because “significant events” at 5.3 is left undefined.
Requirement-area score	93	$(100 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 35 + 22.5 + 19 + 16 = 92.5$, rounded to 93.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.4.1	Section 5.3 lets automated alerting and correlation do “the first-stage review, provided significant events are brought to human attention”. “Significant” is nowhere defined. That one word decides whether the daily review happened at all and I would want it pinned down.	T, A	Minor
10.1.1	Central forwarding of security-relevant logs runs into “where technically feasible” (5.2). The fallback route of documenting the limitation and standing up an equivalent process has nobody attached to it.	A	Minor
10.4.2	Section 5.4 makes monthly the operational default until a targeted risk analysis says otherwise. That analysis has no owner and no date, so I can’t see who starts it.	A	Minor
10.5.1	Section 5.6 asks for archival storage “sufficient to meet the 12-month requirement”. Where it goes and who builds it are both open. No date.	T	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	30 applicable sub-requirements. 29 full

Criterion	Score, 0 to 100	Evidence or comment
		and 12.6.2 largely with nothing partial and nothing absent. 89 of 90 points, $100 \times 89 / 90 = 98.9$, rounded once to 99.
Accuracy	90	Midpoint, and I cited nothing. Section 1.4 gets the regulatory boundary right and asserts no Financial Conduct Authority obligation. The 72-hour notification at 11.8 is put as a data protection duty and never as a PCI DSS one, which is the separation I'd want to see. None of the four defect kinds.
Proportionality and scope fit	95	90 and up one, for the 2 clauses that decide whether we could operate this at all. 11.3 gives an on-call rota with a primary and a backup in place of a security operations centre. 15.1 says controlled spreadsheets and existing tooling can serve as the registers and that no governance platform has to be bought — the first time I have seen anybody write that down.
Enforceability and clarity	80	70 and up twice. 14.1 gives an exception record with an owner and an expiry date and the approvals on it while 13.3 gives a compliance calendar whose evidence fields name the control, the date, the responsible person and the outcome. It stays below 81 because “material”, “applicable” and “where proportionate” qualify a great many of the governance obligations and each of those is a judgment somebody has to make. I would want to know who.
Requirement-area score	92	$(99 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 34.65 + 22.5 + 19 + 16 = 92.15$, rounded to 92.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.6.2	Nothing brings the security awareness programme itself back for annual review or refreshes it against new threats, so nothing in here would tell me the training had gone stale. Section	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	9 covers delivery and content and stops there.		
12.2.1	Section 6.3 requires an approved technology list and names nobody to approve it, where the sub-requirement wants explicit approval by authorised parties.	A	Minor
12.10.3	The rota at 11.3 is the right shape and nobody owns it. The acquirer contact route it depends on turns up only as a required content item of the plan, which isn't where I would put it.	A	Minor
12.8.2	Contracts missing the required acknowledgement get addressed "at renewal or sooner according to risk" (10.2). No backstop date. 11 suppliers touch the cloud environment.	A, L	Minor
12.3.1	Section 7.1 puts the targeted risk analysis register on the Information Security Manager and then sets no date for the first analyses. None of them exists.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	
8.2.1 Unique ID assigned to every	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
user before access is allowed			
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Partially addressed	1	Not stated. Section 4.6 begins "Authentication factors shall be protected as confidential security credentials" and goes straight to password parameters; the obligation that all user and administrator access is authenticated by one of the three permitted factor types appears nowhere.
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	
8.3.5 First-time and	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
reset passwords set uniquely and changed on first use			
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Largely addressed	2	“They shall contain alphabetic and numeric characters where required by PCI DSS” (4.6). The twelve-character minimum is stated at full strength; the complexity element is made conditional where the standard is not.
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Largely addressed	2	“NorthPay may remove unnecessary routine password expiry for accounts protected by MFA only where doing so remains consistent with the applicable PCI DSS authentication requirements” (4.6). The ninety-day change is stated and then qualified by a discretion the clause does not resolve.
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
originating outside the network			
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	Yes. Of the four this is the one I'd put in front of an assessor. First challenge is 4.6 and "alphabetic and numeric characters where required by PCI DSS", because there's no condition on it in the standard and that hedge is exactly the kind of sentence an engineer reads once and then configures against.
Anything that reads as compliant on the surface but would not hold.	The password-expiry carve-out at 4.6 reads to me as a decision somebody has already taken, wrapped in "only where doing so remains consistent with the applicable PCI DSS authentication requirements". Either an account is single-factor and its password changes every 90 days or it isn't, and a policy should say which. Then 5.3, where automated correlation may do the first-stage review "provided significant events are brought to human attention" and whether the daily review happened turns on the word significant. Nobody has defined it.
Any requirement or sub-requirement missed, misstated or invented.	8.3.1 is the real omission, and I went back through section 4 twice before recording it, because the section sets password and lockout and MFA parameters without ever saying that access is authenticated by a

Question	Response
	permitted factor. 12.6.2 is the other, with training delivery covered and the programme itself never put under annual review and update. Nothing invented, no misnumbered obligation, no superseded parameter.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Yes, and it's the only one of the four written as though somebody had counted our staff first. An on-call rota in place of an operations centre, manual SaaS de-provisioning with a completion step recorded, monthly for non-daily log review, spreadsheets as registers. My reservation is length. 22 pages is a maintenance liability for a 61-person merchant with a 2-person security function, and I'd expect the annual review to slip first.
Anything else worth recording.	The data protection and retention material in sections 12 and 13 sits outside the four requirement areas. It didn't move any figure I entered. Policy-level score is the arithmetic mean of my four unrounded requirement-area scores at 91.29, rounded to 91.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Head of IT and Security
Years of experience with PCI DSS	12 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	11	90	70	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P2a

Date completed: 22 Aug 2026

Reviewer identifier: R2 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	9 applicable sub-requirements with 8 full and 7.1.2 largely and no partials and nothing left out. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96. The figure argues with my impression of the area and I'm letting both stand, because every sub-requirement is here for the single reason that the text reproduces the standard. Section 2 has no actor in it, no "shall" and no named role. Coverage measures presence. Presence is what this policy has.
Accuracy	90	Straight to the midpoint of 81 to 100, because the wording tracks version 4.0.1 closely and the citations at 2.1 to 2.6 resolve and I can't find a single parameter drawn from a superseded version.
Proportionality and scope fit	70	Midpoint of 61 to 80. Nothing here is disproportionate and no control assumes capacity NorthPay hasn't got. It doesn't reach the band above because scope is only ever stated in the standard's own terms. Section 1 talks about components that store, process or transmit cardholder data and 2.6 restates query access to repositories of stored cardholder data, while at no point does anyone acknowledge that no primary account number rests on a NorthPay system. This area would read the same for a bank.
Enforceability and clarity	55	Midpoint of 41 to 60 and up one step for the 6-month cadence at 2.4.1 and

Criterion	Score, 0 to 100	Evidence or comment
		approval before access at 2.3.2, both of which an assessor can test directly. It stays in this band because every clause is in the present indicative — “are reviewed”, “is assigned” — so the text describes how things are and puts a duty on nobody. No role is named in section 2 at all. None.
Requirement-area score	81	$(96 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (55 \times 0.20) = 33.6 + 22.5 + 14 + 11 = 81.1$, rounded to 81.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.2	“Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood” (2.1.2). That is the standard copied across. No role is named anywhere in section 2 so I can’t see that anything has been applied.	A	Minor
7.2.4	“All user accounts and related access privileges ... are reviewed at least once every six months” (2.4.1) tells me the review happens. Nobody is required to perform it. Nobody owns it.	A	Minor
7.2.3	“Required privileges are approved by authorised personnel before access is granted” (2.3.2). I can find no approver identified for NorthPay anywhere.	A	Minor
7.2.6	2.6.1 and 2.6.2 come across with no note that NorthPay holds no repository of stored cardholder data. As written I can neither apply the clause nor rule it out.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	The checklist at D.13.5 comes out at 71 of 72 points, $100 \times 71 / 72 = 98.6$, rounded once to 99. 23 fully addressed and 8.1.2 largely. Recorded disagreement: this is the highest coverage figure I've given any policy in this area and it's the policy I'd least want to operate, because what the instrument measures here is reproduction of the standard and that is the thing this text does best.
Accuracy	90	Band midpoint again and I cited nothing to move it. 12 characters, 10 attempts, 30 minutes, 15 minutes, 90 days and 4 previous passwords are all version 4.0.1 figures and the 8.3.x and 8.6.x citations resolve when I follow them.
Proportionality and scope fit	70	Midpoint of 61 to 80. No control assumes capacity the scenario hasn't got and our identity provider could enforce the lot. Below the band above because nothing in section 3 looks at NorthPay's estate. The 10-character minimum in force goes unmentioned. So does the session that never times out, and so does multi-factor authentication reaching only the AWS console and the collaboration suite.
Enforceability and clarity	55	50 and up one, for parameters an assessor can test directly. The declarative form holds it in this band, because "Access for terminated users is immediately revoked" (3.2.4) states a fact while removal from the software-as-a-service platforms is done by hand and nobody is named to do it.
Requirement-area score	82	$(99 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (55 \times 0.20) = 34.65 + 22.5 + 14 + 11 = 82.15$, rounded to 82.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.1.2	Same as 7.1.2. 3.1.2 carries the obligation across and assigns nothing. No role appears anywhere in section 3.	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.2.5	I read “Access for terminated users is immediately revoked” (3.2.4) as a statement of fact that lands on nobody as a duty. No owner. No acknowledgement that removal from each platform is done by hand.	A, T	Minor
8.3.6	The 12-character minimum at 3.3.5 arrives with no reference to the 10-character minimum in force. No remediation date and nobody owns it, which leaves me nothing to chase.	T	Minor
8.4.2	MFA for all non-console access into the cardholder data environment (3.4.2) says nothing about the systems that don’t have it and sets no implementation date.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	9 applicable sub-requirements. I have 8 full and 10.1.2 largely with nothing below that. 26 of 27 points, $100 \times 26 / 27 = 96.3$, rounded once to 96.
Accuracy	90	90 is the midpoint and I left it there. Retention and review and failure-response wording all match version 4.0.1 and the cross-reference to 12.3.1 at 4.3.3 is correct.
Proportionality and scope fit	65	70 and down one. This area asserts an operating pattern we don’t have and says nothing about how anyone moves toward it. 4.3.1 restates the daily review and 4.4.1 the 12-month retention. Neither mentions the 90-day searchable retention we actually run, or the administrator log that never reaches the security information and event management platform, or the hours the alert mailbox is watched.
Enforceability and clarity	55	50 and up one, for the daily and 12-month cadences which are testable. No reviewer is named anywhere in section 4

Criterion	Score, 0 to 100	Evidence or comment
		and every clause reads to me as an assertion where an obligation should be. Every one of them.
Requirement-area score	80	$(96 \times 0.35) + (90 \times 0.25) + (65 \times 0.20) + (55 \times 0.20) = 33.6 + 22.5 + 13 + 11 = 80.1$, rounded to 80.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.4.1	"The following audit logs are reviewed at least once daily" (4.3.1) names no reviewer and sets no operating pattern. The administrator log that never reaches the SIEM goes unaddressed and so does anything arriving outside 08:00 to 18:00 on working days.	A, T	Minor
10.5.1	12-month retention with 3 months immediately available (4.4.1), asserted against a 90-day searchable retention and no archive at all. Nothing requires anyone to close that gap and we would carry it into an assessment.	T	Minor
10.1.2	10.1.2 turns up at 4.1.2 word for word. No logging or review or investigation responsibility is assigned to anyone, so I have nothing to test.	A	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	98	30 applicable sub-requirements. 28 full with 12.1.3 and 12.1.4 largely and no partials and no gaps. 88 of 90 points, $100 \times 88 / 90 = 97.8$, rounded once to 98. Recorded disagreement: 5.8.1 states that an incident response plan exists and NorthPay has none, so coverage counts the obligation as present while my judgment of the area sits in the findings and in the overall judgement.
Accuracy	90	The midpoint, untouched. None of the four defect kinds. The reference to a

Criterion	Score, 0 to 100	Evidence or comment
		Chief Information Security Officer at 5.1.4 is the standard's own wording so I don't score it as a misstatement, though it assigns nothing here.
Proportionality and scope fit	65	70 and down one. Nothing anywhere in this area reflects a security function of 2 people. 5.8.3 restates the 24/7 designation without a mechanism. The area assumes an incident response plan, a third-party service provider register, a cryptographic inventory and a targeted risk analysis programme, none of which we have, and it names nobody to build any of them.
Enforceability and clarity	50	Midpoint of 41 to 60 with nothing cited. Frequencies are stated. Against that, "periodically" and "promptly" and "appropriately and periodically trained" keep recurring and no role is named in section 5, while the present tense asserts each programme into existence without requiring anybody at all to build it.
Requirement-area score	80	$(98 \times 0.35) + (90 \times 0.25) + (65 \times 0.20) + (50 \times 0.20) = 34.3 + 22.5 + 13 + 10 = 79.8$, rounded to 80.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.10.1	"An incident response plan exists and is ready to be activated" (5.8.1). It doesn't. No roles are assigned for a suspected compromise of card data and no duty falls on anyone to write the thing. An assessor records this as not in place and so do I.	A	Critical
12.1.4	5.1.4 carries across the requirement to assign responsibility to a Chief Information Security Officer or other knowledgeable member of executive management and then doesn't assign it. NorthPay has no such officer. The header names an approver, which isn't the same as a holder of the	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	responsibility.		
12.10.3	“Specific personnel are designated to be available on a 24/7 basis” (5.8.3). Nobody is designated, and no rota or deputy or contact route is required.	A	Major
12.3.1	5.3.1 sets out the elements of a targeted risk analysis and then requires nobody to produce one. No date either. None exists and nothing here gets us to the first.	A	Minor
12.8.1	5.7.1 to 5.7.5 assert that the register and the written agreements and the due diligence process and the annual monitoring are all in place. No owner against any of them and no start date, so I can’t date the first piece of work.	A	Minor
12.6.3	5.5.3 asserts that training is delivered and acknowledged annually. Nobody owns it and no completion threshold is set. The position as it stands goes unmentioned, which is where I would have started.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	
8.1.2 Roles and responsibilities documented, assigned and understood	Largely addressed	2	“Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood” (3.1.2), reproduced verbatim. No role is named anywhere in

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			section 3, so the obligation to assign is stated and not discharged.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	
8.3.4 Invalid authentication attempts limited by logout	Fully addressed	3	
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented	Fully	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
and communicated to all users	addressed		
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	It comes apart at the first document request. Everything is stated and nothing is owned, and then 5.8.1 tells the assessor that an incident response plan exists. That's the sentence I'd challenge first. NorthPay has no plan and nobody holds a role for a suspected card compromise and the notification path to the acquirer has never been tested, and this policy puts no duty on anyone to change any of it. On the day it matters we would be working out who calls the acquirer while the storefront is still

Question	Response
	taking orders.
Anything that reads as compliant on the surface but would not hold.	All of it, and that's the difficulty. Take a clause at a time and it's faultless, because it is the standard. Take it as a policy and it obliges nobody. There's no "shall" in the document and no named role below the header, while every control is written as a description of what already happens. 7 pages, and I can't point to one sentence a person could be held to at a management review. Nobody could be in breach of it, which is another way of saying it isn't doing the job of a policy.
Any requirement or sub-requirement missed, misstated or invented.	Nothing invented and no misattributed number. The reproduction is accurate throughout and the parameters are the version 4.0.1 figures. 12.1.4 is restated without responsibility going to anyone, and for an organisation with no Chief Information Security Officer that leaves the requirement unmet by the very policy quoting it. Among the four areas I found the same shape at 7.1.2, 8.1.2, 10.1.2 and 12.1.3 — the obligation to assign roles, copied out and never performed.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	We could adopt it this afternoon and nothing would change. Nobody would do anything differently on Monday because no clause tells anybody to do anything, and size isn't the reason either, since a policy written this way fails in a company of any size. What's in its favour is that a competent reader could turn each clause into an obligation without having to argue about what the standard requires, and I'd rather start from that than from a document I have to unpick.
Anything else worth recording.	Highest coverage figures of the four policies I scored and the lowest enforceability figures, and I've left both standing without adjusting either. A rubric weighting coverage at 35 rewards a document that reproduces the standard and this is the case that shows it. Policy-level score, taking the arithmetic mean of the four unrounded area scores, comes to 80.79, rounded to 81.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Head of IT and Security
Years of experience with PCI DSS	12 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	11	90	70	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P2b

Date completed: 22 Aug 2026

Reviewer identifier: R2 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	89	I make it 9 applicable sub-requirements with 6 full and 3 largely at 7.1.1, 7.2.1 and 7.2.5.1. Nothing partial and nothing absent. 24 of 27 points, $100 \times 24 / 27 = 88.9$, rounded once to 89.
Accuracy	90	90, which is the midpoint, and nothing shifted it. Citations at sections 2 and 3 resolve, the 6-month interval is the version 4.0.1 figure and I can't find anything invented.
Proportionality and scope fit	70	90 and down twice. At that point the band above stops describing it. Section 1 says the cardholder data environment "comprises the online storefront, checkout page, order-management platform, administrator access paths". The scenario has those connecting to or impacting the CDE — a different thing altogether and the whole of our scoping position. Against that, 3.2 routes approvals through the line manager and the Information Security Manager and the Chief Technology Officer, which is the establishment we actually have.
Enforceability and clarity	75	70 and up one, for 3.2, which names who raises a request and who approves it and who approves privileged access. Below the band above because 3.1 and 3.3 are in the present indicative and because nobody owns the six-monthly review. And because "data that could lead to it" (3.5) isn't a boundary I can test.
Requirement-area	83	$(89 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) +$

Criterion	Score, 0 to 100	Evidence or comment
score		$(75 \times 0.20) = 31.15 + 22.5 + 14 + 15 = 82.65$, rounded to 83.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.1	There is no statement covering the Requirement 7 policies and operational procedures, and I take the document control block as reaching this policy on its own. Nothing anywhere addresses the procedures being in use.	A	Minor
7.2.1	No access control model is defined. Section 3.1 gives least privilege and job classification and stops short of access appropriate to the business and access needs. The model itself never appears, so I can't tell how access is meant to be granted.	A	Minor
7.2.5.1	Section 3.4 has the periodic review at the risk-analysis frequency and the management acknowledgement, and it drops the requirement that inappropriate application and system account access is addressed.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	89	D.13.5 leaves me 64 of 72 points, $100 \times 64 / 72 = 88.9$, rounded once to 89. 18 fully addressed and 5 largely with nothing partial. 8.3.3 isn't addressed at all.
Accuracy	90	Midpoint again and nothing cited. Parameters match version 4.0.1. "Revoked immediately on the last working day" (4.3) weakens 8.2.5

Criterion	Score, 0 to 100	Evidence or comment
		without misstating anything so I've recorded it under coverage.
Proportionality and scope fit	75	70 and up one, for 4.9. It starts where we are with multi-factor authentication on the AWS console and the collaboration suite, then extends it by name to the order management platform and to the payment service provider merchant portal and the helpdesk platform. Everything else runs through the identity provider we already have. I see no capacity question in the area.
Enforceability and clarity	70	70 with one step each way. Up for the numeric parameters at 4.7 and 4.8. Down because "revoked immediately on the last working day (or sooner if the circumstances require)" (4.3) can't be tested — immediately and on the last working day are two different commitments — and because nobody owns the joiner, mover and leaver process from end to end. Net 70.
Requirement-area score	83	$(89 \times 0.35) + (90 \times 0.25) + (75 \times 0.20) + (70 \times 0.20) = 31.15 + 22.5 + 15 + 14 = 82.65$, rounded to 83.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.3.3	Absent. Nothing here requires a user's identity to be verified before an authentication factor gets modified, and section 4.2 requires approval for the change which is 8.2.4 and a different control altogether. This is the gap that turns a helpdesk call into an account takeover.	T, A	Major
8.2.5	"Access for terminated users is revoked immediately on the last working day (or sooner if the circumstances require)" (4.3). Immediately and on the last working day are 2 different commitments. As written I can't test either.	T	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.2.2	Section 4.1 leaves out 2 elements of the exception, and I make them documented business justification for the shared account and confirmation of the individual's identity before access to it is granted.	A	Minor
8.6.1	Section 4.11 drops documented business justification and confirmation of individual identity for interactive use of system and application accounts.	T, A	Minor
8.3.8	Section 4.12 gives the content of the guidance and never requires the authentication policies and procedures themselves to be documented and communicated to all users.	A	Minor
8.1.1	The Requirement 8 procedures are never said to be in use. Document control gets as far as this policy and no further.	A	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	93	I have 7 of the 9 applicable sub-requirements full and 2 largely at 10.1.1 and 10.7.3, with no partials at all. 25 of 27 points, $100 \times 25 / 27 = 92.6$, rounded once to 93.
Accuracy	90	Band midpoint, unmoved. 12-month retention with 3 months immediately available matches version 4.0.1 and the cross-reference to 12.3.1 at 5.4 is correct.
Proportionality and scope fit	75	70 and up one, for 5.6. It names the 90-day retention in the security information and event management platform as it stands and requires it to be extended or supplemented by an offline archive. No control in the area assumes capacity the scenario doesn't state.
Enforceability and clarity	70	70 with one step each way. Up for the daily and 12-month cadences and the 3-month deadline on defining retention

Criterion	Score, 0 to 100	Evidence or comment
		schedules. Down because 5.3 names no reviewer for the daily review and nothing addresses events arriving outside 08:00 to 18:00 on working days. Down again because “will be extended or supplemented” (5.6) is an intention where a duty belongs. Net 70.
Requirement-area score	84	$(93 \times 0.35) + (90 \times 0.25) + (75 \times 0.20) + (70 \times 0.20) = 32.55 + 22.5 + 15 + 14 = 84.05$, rounded to 84.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.7.3	Section 5.7 records the duration and the cause of a critical security control failure and leaves out documenting the remediation required.	T	Minor
10.1.1	Absent. No statement that the Requirement 10 policies and operational procedures are documented, kept up to date, in use and known to affected parties.	A	Minor
10.4.1	Section 5.3 names no reviewer for the daily review. It says nothing about how an evening or weekend event reaches a person, while the alerts land in a mailbox watched 08:00 to 18:00 on working days, which is where I would expect the failure to show.	A	Minor
10.5.1	“Current SIEM retention of 90 days will be extended or supplemented by offline archive to meet this requirement” (5.6). That is an intention where an obligation should sit and it carries no date and nobody’s name.	T	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	80	30 applicable sub-requirements. I have 20 full and 6 largely with nothing partial. 4 are not addressed at all: 12.3.2,

Criterion	Score, 0 to 100	Evidence or comment
		12.3.3, 12.3.4 and 12.6.2. 72 of 90 points, $100 \times 72 / 90 = 80$.
Accuracy	90	90 at the midpoint. "This restriction is enforced by conditional-access policy" (6.2) isn't true of our estate. It still isn't one of the four defect kinds, because nothing about the standard is invented and no sub-requirement number is misattributed. I've recorded it as a finding and carried it in proportionality.
Proportionality and scope fit	70	70 with one step each way. Up because the establishment is described as it is — 61 staff and a 2-person function, a compliance analyst on 3 days, no steering group and the 78 per cent completion rate named and rejected. Down for 6.2. It records a conditional-access control the scenario says we don't have, and once you assert a control is in place nobody moves toward building it. Net 70.
Enforceability and clarity	75	70 and up one. Section 7 names the Information Security Manager as reviewer and the CTO as approver while there's a 3-month deadline on retention schedules. Below the band above because 6.7 and 6.8 slip back into the present indicative and put no owner on the third-party service provider register and none on the incident response plan or the 24/7 designation. That last one is what I would chase.
Requirement-area score	80	$(80 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (75 \times 0.20) = 28 + 22.5 + 14 + 15 = 79.5$, rounded to 80.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.3.3	Absent. No inventory of cryptographic cipher suites and protocols, and no annual review of one. Nothing on anticipated changes in cryptographic vulnerabilities either. Certificate expiry sits in one of our engineers'	T	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	spreadsheets today and nothing here displaces that.		
12.3.4	Absent. Nothing reviews hardware and software technologies annually and nothing tracks end of life. No remediation plan for outdated technology goes to senior management for approval.	T, A	Major
12.3.2	Absent. The customized approach goes unmentioned along with the targeted risk analysis and controls matrix it requires.	A	Major
12.6.2	Absent. Section 6.5 handles delivery of the training. The programme itself is never made subject to review at least every 12 months and nothing updates it for new threats.	A	Major
12.2.1	“This restriction is enforced by conditional-access policy” (6.2). In practice it is enforced by convention, and the clause also leaves out the list of company-approved hardware and software products and names nobody authorised to approve the acceptable use rules.	T, A	Major
12.5.2	Section 6.4 leaves out updating the data-flow diagrams and the justification for environments treated as out of scope. Section 1 also has the storefront, checkout page, order-management platform and administrator access paths comprising the CDE, where they connect to or impact it.	A	Major
12.10.5	Section 6.8 cuts the alert sources down to “alerts from security systems”. Nothing names the change- and tamper-detection mechanism for payment pages, change detection for critical files, network security controls or detection of unauthorised wireless access points.	T	Major
12.10.7	Section 6.8 skips identifying whether sensitive authentication data sits alongside a primary account number	T	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	found somewhere it isn't expected.		
12.8.3	Section 6.7 requires due diligence before engagement and sets up no process for engaging third-party service providers at all. 11 suppliers touch our cloud environment and no register exists.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Largely addressed	2	The document control block covers this policy – published on the intranet, issued to staff and relevant suppliers, acknowledged and reviewed annually – but no clause states that the Requirement 8 operational procedures are in use.
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	
8.2.2 Group, shared or generic IDs used only by managed exception	Largely addressed	2	“Shared, group or generic accounts are forbidden except in documented, time-limited exceptional circumstances that are approved by management and that still allow actions to be attributed to an

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			individual” (4.1). Documented business justification and confirmation of the individual’s identity before access is granted are not stated.
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	
8.2.5 Access for terminated users revoked immediately	Largely addressed	2	“Access for terminated users is revoked immediately on the last working day (or sooner if the circumstances require)” (4.3). Immediate revocation and revocation on the last working day are different commitments.
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	
8.3.3 Identity verified before an authentication factor is changed	Not addressed	0	Absent.
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	
8.3.8 Authentication policies documented and communicated to all users	Largely addressed	2	"Users are given clear guidance on choosing strong authentication factors, protecting them, never re-using passwords, and reporting any suspicion of compromise" (4.12). The requirement that the authentication policies and procedures themselves are documented and communicated to all users is not stated.
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	
8.4.3 MFA for all remote access	Fully addressed	3	

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
originating outside the network			
8.6.1 Interactive login by system or application accounts controlled	Largely addressed	2	“Application and system accounts that allow interactive login are treated as exceptional, time-limited, approved and attributable to an individual” (4.11). Documented business justification and confirmation of individual identity before access are not stated.
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	No. It's the missing material that does the damage. Requirement 12.3 is most of it — no cryptographic inventory, no annual technology review and nothing on the customized approach. But 6.2 is what I'd challenge first. It says personal devices are kept off CDE-connected systems by conditional-access policy. They're kept off by convention. Record a control as already in place and the pressure to build it disappears, and an assessor will read this one as a claim.
Anything that reads as compliant on the surface but would not hold.	Section 6.8 packs the whole of 12.10 into one block and reads as finished to me. It

Question	Response
	isn't. The alert sources at 12.10.5 come down to "alerts from security systems" while the PAN-discovery procedure never checks whether sensitive authentication data sits with the PAN. Then 4.3, where "revoked immediately on the last working day" sounds decisive and is 2 different commitments in a single sentence.
Any requirement or sub-requirement missed, misstated or invented.	Missed entirely on my count: 12.3.2, 12.3.3, 12.3.4 and 12.6.2. And 8.3.3, which is the control that stops a helpdesk call becoming an account takeover. Misstated: the CDE definition in section 1 treating the connected systems as the CDE itself, and the conditional-access claim at 6.2. Nothing is invented and nothing carries a sub-requirement number it doesn't belong to.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Yes, and more readily than any of the other three. 5 pages. The roles that actually exist are the ones named. Approvals sit with line managers and the Information Security Manager, and the retention work has a 3-month deadline on it instead of being left open. The gaps are real. My judgment is that adding 4 missing controls to a document people would actually use is a far easier problem than taking an unenforceable document and making somebody accountable for every line of it.
Anything else worth recording.	This is the only one of the four that says what's wrong today and puts a date on fixing it, and it's also the only one claiming a control we haven't got. I'd record both. Policy-level score works out at 82.21 on the arithmetic mean of the four unrounded requirement-area scores, rounded to 82.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Head of IT and Security
Years of experience with PCI DSS	12 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P1a

Date completed: 22 Aug 2026

Reviewer identifier: R3 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	100	Calculated rather than estimated: 27 of 27 points across the 9 applicable sub-requirements at $100 \times 27 / 27 = 100$. Fully addressed 9, largely 0, partially 0, not addressed 0. Section 1.4 carries 7.1.1 with all four elements and 1.3 carries 7.1.2. Clauses 2.1 to 2.5 track 7.2.1 to 7.2.6 one clause at a time and include both the six-month interval at 2.3 and the four review outcomes.
Accuracy	90	Entered at the centre of the 81 to 100 band with nothing found to move it either way, since every cited number resolves to the obligation beside it: 7.2.3 and 8.2.4 sit together at 2.2 with 7.2.5.1 at 2.4 and 7.2.6 at 2.5. The six-month interval is the v4.0.1 figure and nothing is asserted that the standard does not contain, so none of the four defect types appears here.
Proportionality and scope fit	90	Held at the 81 to 100 centre. Nothing here assumes a capability the scenario withholds: clause 2.1 requires obsolete project group memberships to be revoked, which is exactly the condition described, and the work is done inside the identity provider's own group model. Clause 2.5 handles the absence of stored PAN cleanly and neither assumes PAN is held nor uses the absence to soften the control.
Enforceability and clarity	65	Entered at 70 (the middle of 61 to 80) and moved one step down to 65. I took the step down for approvers: clause 2.2

Criterion	Score, 0 to 100	Evidence or comment
		wants 'appropriate authorization' and privileges 'approved by authorized personnel' while 2.3 sets a six-month review with nobody named to run it. What holds the score inside the band is that the frequencies and the review outcomes are both stated. Ownership stops at section 1.3, which promises only that responsibilities 'shall be documented, assigned and communicated' somewhere else.
Requirement-area score	89	$(100 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (65 \times 0.20) = 35 + 22.5 + 18 + 13 = 88.5$, rounded to 89.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.2.3	Clause 2.2 requires privileges to be 'approved by authorized personnel' and changes to identity objects to carry 'appropriate authorization', and neither phrase resolves to a role or a grade anywhere in the document, so as written there is no approver to test.	A	Minor
7.2.4	Six months is stated at 2.3 and so are the four outcomes. The reviewer is not named, no record of the outcome is called for and no limit is set on how long inappropriate access may sit once it has been found.	A	Minor
7.2.5.1	Clause 2.4 hands the application and system account review interval to a targeted risk analysis. Section 5.3 requires that analysis to exist and gives it no first date and no interim interval, so from the day of adoption the review runs to no frequency at all.	A	Minor
7.2.6	Clause 2.5 opens on a condition: 'Where a repository of stored cardholder data exists within scope'. Nothing requires anyone to establish whether one does, so the trigger is never tested and the last-four-digit records in the order management	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	platform fall outside the clause on either reading.		

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	97	Checklist result of 70 of 72 points: $100 \times 70 / 72 = 97.2$ which rounds once to 97. Twenty-two fully addressed and two largely addressed (8.2.7 and 8.3.8), both losing a point for want of an owner and a cadence on an activity the sub-requirement makes recurring. Section 3 reproduces every applicable sub-requirement, 8.6.1 to 8.6.3 among them, which a policy of this length usually drops.
Accuracy	90	Centre of the 81 to 100 band with nothing cited either way. Every parameter is the current v4.0.1 figure and no superseded value survives anywhere in the section: 12 characters with the eight-character fallback, 90 days, 10 attempts, 30 minutes, 15 minutes, 90 days inactivity, four previous passwords. Clause 3.8 picks up the ten-character identity provider minimum as short of the standard and requires it raised, which is the current parameter applied correctly.
Proportionality and scope fit	80	Entered at 70 (the middle of 61 to 80) and up two steps to 80. One step for putting enforcement on the identity provider, which the scenario says federates every in-scope application and supplies both MFA and conditional access, and one more for clause 3.11 refusing the current AWS-console-and-

Criterion	Score, 0 to 100	Evidence or comment
		collaboration-suite position in terms. It stops short of the band above because of 3.5: 15-minute re-authentication on 'relevant SaaS applications' and no session configuration that persists while a browser tab stays open. That is a demand on the order management platform's session handling and the scenario nowhere states NorthPay controls it.
Enforceability and clarity	75	Entered at 70 then up twice and down once. Up because every authentication obligation carries a number, so each one can be tested against a configuration, and up again for the exceptions at 3.2 and 3.12 which carry an explicit management approval and a time limit. Down because section 3 names nobody: it is 'NorthPay shall' from end to end, with assignment pushed out to documents that section 1.3 merely says will exist.
Requirement-area score	87	$(97 \times 0.35) + (90 \times 0.25) + (80 \times 0.20) + (75 \times 0.20) = 33.95 + 22.5 + 16 + 15 = 87.45$, rounded to 87.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.2.8	Clause 3.5 sets the 15-minute rule and adds that 'Session configurations that permit indefinite authenticated access while a browser remains open shall not be used'. The order management platform behaves exactly that way and it is a third-party service, yet no deadline is set and no owner is named. No alternative is offered either, such as forced re-authentication at the identity provider.	T	Major
8.2.7	'Use of such accounts shall be monitored for unexpected activity' (3.4). Who monitors is not stated and neither is the interval, and 'unexpected activity' has no definition. As written,	T, A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	none of it converts into a configuration or a test.		
8.3.8	Clause 3.9 requires authentication guidance to be documented and communicated to users. It needs to name the author, the channel, the issue interval and the record showing users received it. None of the four is there.	A	Minor
8.2.5	'Access for terminated users shall be revoked immediately' (3.3) is stated at full strength and no owner sits behind it. The software-as-a-service platforms the scenario says are de-provisioned by hand get no per-platform step, and 'immediately' comes with nothing to evidence it.	A, T	Minor
8.1.2	Section 1.3 says responsibilities for identity management and authentication 'shall be documented, assigned and communicated', which is a promise to assign rather than an assignment. Password standard configuration, MFA enforcement, lockout settings and account de-provisioning are all left without a role.	A	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	100	Calculated: 27 of 27 points across the 9 applicable sub-requirements at $100 \times 27 / 27 = 100$. Fully addressed 9, largely 0, partially 0, not addressed 0. Clause 4.6 states the 12-month and three-month figures then commits to archival beyond the 90-day searchable window, and 4.7 reproduces all seven elements of 10.7.3.
Accuracy	90	Mid-band at 81 to 100 and unmoved, because the citations at 4.2 to 4.7 all resolve and the daily interval, the 12-month history and the three-month immediate availability are v4.0.1 figures.
Proportionality and	70	Entered at 70 (the middle of 61 to 80)

Criterion	Score, 0 to 100	Evidence or comment
scope fit		with one step up and one step back down, so it lands where it started. Up because the retention remedy at 4.6 is written against the real 90-day SIEM licence and could be met with the cloud storage the scenario says is already in use. Down for 4.3, which wants the daily review 'irrespective of normal office hours' and 'supported by procedures that ensure required reviews occur every day' with no rota and no named reviewer behind it and no allowance for automated first-stage triage, against a security function of two and an alert mailbox watched 08:00 to 18:00 on working days.
Enforceability and clarity	65	Entered at 70 then up once and down twice. Up for cadence and retention figures an assessor could test directly. Down because nobody in section 4 is a reviewer, an investigator or an approver, and 4.1 states that responsibilities 'shall be assigned and understood' and assigns none of them. Down again for 4.4, where 'relevant administrator activity logs' go into 'the applicable review arrangements' with no word on which cadence catches them.
Requirement-area score	85	$(100 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (65 \times 0.20) = 35 + 22.5 + 14 + 13 = 84.5$, rounded to 85.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.5.1	Clause 4.6 asks for 'retention or archival arrangements sufficient' to bridge the 90-day searchable window. Name the store. Say who builds it and by when, and require the archived history to be protected against alteration and deletion. As written the 12-month history never comes into being.	T	Major
10.1.2	Clause 4.1 lists four things: operating	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	logging controls, conducting reviews, investigating anomalies and responding to control failures. Responsibility for them 'shall be assigned and understood' and none of it is assigned here.		
10.4.1	The daily review has no named reviewer and no rota, and nothing records what it produces. The only mechanism offered is 'procedures that ensure required reviews occur every day', and no date is set by which those procedures must exist.	A, T	Minor
10.4.2, 10.4.2.1	Clause 4.4 sends the periodic interval to a targeted risk analysis, sets no interim default and gives the first analysis no date. The order management platform's administrator log, which the scenario says is not forwarded to the SIEM, is dropped into 'the applicable review arrangements' with no statement of which ones apply.	A	Minor
10.3.1	Clause 4.2 limits read access to personnel with 'a documented job-related need'. Nothing says who documents the need or approves it and nothing says where the record is held.	A	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	100	Calculated: 90 of 90 points across the 30 applicable sub-requirements at $100 \times 90 / 90 = 100$. Fully addressed 30, largely 0, partially 0, not addressed 0. Sections 5 to 8 carry every applicable sub-requirement including 12.3.2, 12.3.3 and 12.3.4, and clause 8.5 reproduces the payment-page change-and-tamper-detection bullet with its applicability status intact.
Accuracy	90	Mid-band at 81 to 100 with nothing to move it. Clause 5.3 names 7.2.5.1,

Criterion	Score, 0 to 100	Evidence or comment
		8.6.3, 10.4.2.1 and 12.10.4.1 as the targeted-risk-analysis dependencies and all four are right, 5.4 ties the customized approach to the controls matrix and the risk analysis correctly, and discharging 12.1.4 on the CTO is something the standard permits. No obligation appears that the standard does not contain.
Proportionality and scope fit	85	Entered at 90 (the middle of 81 to 100) and one step down. Clause 8.3 designates 24/7 availability and asks for coverage 'outside normal office and shared-mailbox monitoring hours' with no rota naming a primary and a deputy and no routing by which an alert reaches whoever is on. It is the heaviest operating demand in the document and it sits on a two-person function with nothing underneath it, while the rest of the area is sized correctly and the no-PAN position is stated without overclaiming and without weakening anything.
Enforceability and clarity	65	Entered at 70 then up once and down twice. Up because every recurring obligation carries a frequency: 12-month policy and programme reviews, training on hire and annually, annual TPSP monitoring, an annual incident-response test. Down because sections 5 to 8 name no accountable role anywhere, which leaves the TPSP register, the cryptographic inventory, the awareness programme and the incident response plan unowned. Down again because the policy leans on documents it requires and never schedules: no first date attaches to the targeted risk analysis and none attaches to the responsibility matrix or the incident response plan either.
Requirement-area score	88	$(100 \times 0.35) + (90 \times 0.25) + (85 \times 0.20) + (65 \times 0.20) = 35 + 22.5 + 17 + 13 = 87.5$, rounded to 88.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.10.3	Clause 8.3 designates 24/7 availability. Outside the hours the shared mailbox is watched there is no rota naming a primary and a deputy and no route by which a high-severity alert reaches the designated responder. The duty is stated with no means of discharging it.	A	Minor
12.3.1	Clause 5.3 requires a targeted risk analysis behind every entity-set frequency, names no owner for it and sets no date for the first ones. Four cadences the policy itself depends on, at 7.2.5.1, 8.6.3, 10.4.2.1 and 12.10.4.1, are undefined from the day it takes effect.	A	Minor
12.1.3	Clause 1.3 requires responsibilities to be defined, made known and acknowledged. It stops short of requiring security responsibilities to appear in job or role descriptions, and that is precisely where the scenario says they are missing for engineering and customer support.	A	Minor
12.8.4	Clause 7.4 narrows annual monitoring to 'applicable TPSPs'. No test for applicability is given and the phrase is never tied back to the register population defined at 7.1.	A	Minor
12.10.1	Clause 8.1 specifies the plan's contents in full. Nothing names its author or its owner and no date is set by which it must exist. The scenario states no security incident response plan has been written.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	Clause 1.4: procedures for Requirements 7, 8 and 10 'documented, kept current, actively used and made known to all affected parties'.
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	Clause 1.3 names the CTO and the Information Security Manager and lists identity management and authentication among responsibilities to be documented, assigned and communicated.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	Clause 3.1: unique ID before access to an in-scope system component; accountability preserved in authentication and logging.
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	Clause 3.2 reproduces all six management conditions.
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	Clauses 2.2 and 3.3: authorised, and implemented only to the extent approved.
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	Clause 3.3: 'Access for terminated users shall be revoked immediately.'
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	Clause 3.3: removed or disabled within 90 days of inactivity.
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Largely addressed	2	Clause 3.4 enables and disables correctly, but 'shall be monitored for unexpected activity' has no named monitor and no interval.
8.2.8 Re-authentication	Fully addressed	3	Clause 3.5: re-authentication after

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
required after 15 minutes idle			more than 15 minutes, extended to administrative and SaaS sessions.
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	Clause 3.6: at least one approved factor, all three types enumerated.
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	Clause 3.6: 'A user's identity shall be verified before any authentication factor is modified.'
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	Clause 3.7: lockout after no more than 10 attempts, for at least 30 minutes or until identity confirmed.
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	Clause 3.8(1): unique first-use and reset value, changed immediately after first use.
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	Clause 3.8(2) and (3): alphabetic and numeric, at least 12 characters with the eight-character fallback, plus a requirement to raise the ten-character configuration.
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	Clause 3.8(4): not the same as any of the previous four.
8.3.8 Authentication policies documented and communicated to all users	Largely addressed	2	Clause 3.9 lists all four guidance topics but sets no owner, no issue cadence and no record of communication.
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	Clause 3.10: at least every 90 days, or dynamic posture analysis.
8.3.11 Tokens, smart cards and certificates assigned to an individual and	Fully addressed	3	Clause 3.6: assigned to individual users, not shared, protected so

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
protected			only the intended user can use them.
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	Clause 3.11(1).
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	Clause 3.11(2), with the explicit statement that MFA is not limited to the AWS console and collaboration suite.
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	Clause 3.11(3).
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	Clause 3.12 reproduces all six conditions on interactive use.
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	Clause 3.12: not hard-coded in scripts, configuration or property files, or bespoke source code.
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	Clause 3.12: changed at a targeted-risk-analysis frequency and on suspected or confirmed compromise, complexity appropriate to that frequency.

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	In substance, largely yes. Every applicable sub-requirement is there across the four areas and at the standard's own parameters. Ownership is what I would challenge first. From section 2 onwards nearly every obligation reads 'NorthPay shall' while section 1.3 promises that the specific responsibilities will be documented and assigned somewhere else. An

Question	Response
	assessment produces the question 'who does this, and show me' several times an hour and this document has no answer to it. Then clause 4.6, the audit-log archive, which is the one place where the policy commits to a mechanism that does not exist without saying what the mechanism is, who builds it or when.
Anything that reads as compliant on the surface but would not hold.	Clause 4.3 is the loudest. A daily log review 'irrespective of normal office hours' reads as a strong control, and with no rota or reviewer and no automation allowance it won't run at the weekend. Clause 4.6 sounds like a retention control and is really a sentence about arrangements with no archive named. Then 2.5, which restricts query access to cardholder-data repositories only 'where a repository of stored cardholder data exists within scope'. Nothing obliges anyone ever to determine whether one does, so the control can be reported as satisfied while never having been evaluated.
Any requirement or sub-requirement missed, misstated or invented.	Nothing missed and nothing invented. The parameters are v4.0.1 throughout, including the one most often got wrong: the 12-character minimum with the eight-character fallback at 3.8. Two obligations come out weaker than the sub-requirement supports rather than misstated, since 8.2.7's monitoring has no monitor and no interval and 8.3.8's guidance has no issue cadence. Clause 3.5's demand on order-management session behaviour is correct as a requirement and has no route to implementation.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Adopt, yes. Enforce as written, only with a second document behind it. The controls are sized right for sixty-one people and a security function of two: six-monthly access reviews and annual governance cycles with enforcement placed at the identity provider. What is absent is the layer that turns the policy into work, meaning a named owner against each clause and a first-production date for the registers, analyses and plans it

Question	Response
	leans on. Two people can operate this. They can't be held to it and neither can anyone else, while no clause names a person.
Anything else worth recording.	The best thing about this policy is that in four places it reads the scenario and answers it instead of reciting the standard: the obsolete project groups at 2.1, the ten-character minimum at 3.8, the AWS-console-only MFA position at 3.11 and the 90-day SIEM window at 4.6. Those clauses are where the document stops sounding generic and the worst thing about it is that it does that nowhere else. Coverage returns 100 in three of the four areas. The arithmetic is right and it fairly reflects what is written; it should not be read as a judgement that the four areas are equally sound, because Requirement 10 is the weakest of them and the calculation has no way to show it. The distance between coverage and enforceability, 100 against 65 in two areas, is where this document actually sits.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Senior Security Consultant
Years of experience with PCI DSS	6 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P1b

Date completed: 22 Aug 2026

Reviewer identifier: R3 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	Calculated rather than estimated: 26 of 27 points across the 9 applicable sub-requirements at $100 \times 26 / 27 = 96.3$ which rounds once to 96. Fully addressed 8, largely 1, partially 0, not addressed 0. One deduction, at 7.2.5.1, where clause 3.5 sets the review at a targeted-risk-analysis frequency and drops two of the sub-requirement's elements.
Accuracy	90	Entered mid-band at 81 to 100 and nothing shifted it. The citations at 3.1 to 3.6 resolve and the six-month interval is the v4.0.1 figure while clause 3.3's statement about three legacy groups left over from a project completed in 2025 is accurate to the scenario and is not invented.
Proportionality and scope fit	95	Entered at 90 (the middle of 81 to 100) and one step up. Clause 2.4 puts a named system owner on every in-scope system and hands access approval and review participation to system and business owners rather than to the two-person security function, which is the choice that makes a six-monthly review of roughly forty accounts survivable at this size. Nothing in the area assumes a capability the scenario withholds, and 3.6 states the no-PAN position and gates any future change to it.
Enforceability and clarity	75	Entered at 70 (the middle of 61 to 80) then up twice and down once. Up for actors named at clause level: the

Criterion	Score, 0 to 100	Evidence or comment
		Information Security Manager tracking access-review completion, managers and system owners approving, and no self-approval of privileged access. Up again for the exception process at section 14, carrying justification, owner, expiry date and approvals. Down because 'reviewed promptly' at 3.3 and 'addressed promptly' at 3.4 set no limit, and because the access-control matrix at 3.1 reaches only 'material in-scope systems' while leaving material undefined.
Requirement-area score	90	$(96 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (75 \times 0.20) = 33.6 + 22.5 + 19 + 15 = 90.1$, rounded to 90.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.2.5.1	Clause 3.5 reviews application and system account access at a targeted-risk-analysis frequency. Two elements of the sub-requirement drop out: inappropriate access being addressed, and management acknowledging that the access remains appropriate.	A	Major
7.2.1	The access-control matrix at 3.1 is required only for 'material in-scope systems' and material carries no definition anywhere in the document. Unless the test is stated, the population the matrix has to cover cannot be settled and completeness can't be demonstrated.	A	Minor
7.2.4	'Address inappropriate access promptly' (3.4) needs a number of days against it and an escalation route where access stays in place. It has neither. A review can be closed as complete with its findings still open.	A	Minor
7.2.5	The application and system account register at 3.5 has no named maintainer and no review cadence of its own, and the only cadence stated is for	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	the access it records.		
7.2.3	Clause 3.2 requires approval by 'the person's manager and/or appropriate system owner'. The and/or leaves it open which approval suffices for a given privilege, and 3.3's legacy group review names no owner at all.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	94	Checklist result of 68 of 72 points: $100 \times 68 / 72 = 94.4$ which rounds once to 94. Twenty-one fully addressed, two largely (8.3.6 and 8.3.11) and one partially (8.3.1), with none absent. Every deduction is a hedge or a dropped element rather than a missing topic.
Accuracy	90	Mid-band at 81 to 100 with nothing cited either way and all parameters at the v4.0.1 figures. The statement at 4.6 that routine expiry may be dropped for MFA-protected accounts is correct, since 8.3.9 bites only on single-factor implementations, and that is a judgement call I record as sound. Nothing is asserted that the standard does not contain.
Proportionality and scope fit	95	Entered at 90 (the middle of 81 to 100) then up twice and down once. Up because clause 4.3 accepts that some SaaS de-provisioning is done by hand and makes the responsible administrator record completion per service instead of assuming automation the scenario says is absent, and up again because 4.8 puts MFA and the device restriction on the central identity provider's conditional

Criterion	Score, 0 to 100	Evidence or comment
		access, which the scenario states is available across the federated applications. Down for 4.9, which requires 'an approved secrets-management mechanism' while the scenario has deployment credentials sitting in repository secrets and names no such mechanism as existing.
Enforceability and clarity	75	Entered at 70 then up twice and down once. Up for actors named at clause level: the responsible administrator records de-provisioning and the Information Security Manager approves persistent third-party access while identity verification before a factor change falls to the service desk or the administrator. Up again for the exceptions at 4.2 and section 14, each carrying an approver, an expiry and an owner. Down for the hedges that recur: 'where technically possible', 'where applicable', 'where required by PCI DSS', 'where the requirement applies', 'where proportionate and technically feasible'. Each of them lets a non-compliant system stay non-compliant while no exception is ever raised.
Requirement-area score	89	$(94 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (75 \times 0.20) = 32.9 + 22.5 + 19 + 15 = 89.4$, rounded to 89.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.3.1	The general obligation is absent: all user and administrator access authenticated by at least one permitted factor. Clause 4.6 starts at password parameters and 4.8 starts at MFA, so an access route using neither, such as the certificate- or key-authenticated path of the SFTP key pair on the finance workstation, falls under no authentication rule at all.	T	Major
8.2.8	'Shall be remediated or otherwise	T	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	brought into compliance where the requirement applies' (4.5). The scenario has order-management sessions that never time out while a tab stays open, and this clause gives that no deadline, no owner and no compensating control.		
8.3.6	'They shall contain alphabetic and numeric characters where required by PCI DSS' (4.6, item 2). The composition rule points back at itself, and an engineer configuring the identity provider policy can't read the character set off this document.	T	Minor
8.3.11	Clause 4.6 states that tokens and certificates assigned to individuals shall not be shared. The sub-requirement's second element drops out: the physical or logical controls that ensure only the intended user can use the factor.	T	Minor
8.4.2	Clause 4.8 qualifies the population as 'all applicable non-console access into the CDE' and the sentence naming the order management platform, PSP portal and other systems is itself prefaced 'where applicable'. Applicability is never defined, so whoever configures the tenant sets the enforcement boundary.	T	Minor
8.6.3	Clause 4.9 sends rotation frequency to a targeted risk analysis with no interim default and no date for the first analysis, so on the day the policy takes effect application and system account credentials rotate on no interval at all.	T, A	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	100	Calculated: 27 of 27 points across the 9 applicable sub-requirements at $100 \times 27 / 27 = 100$. Fully addressed 9, largely 0, partially 0, not addressed 0. Clause 5.4 goes past the sub-requirement and makes monthly the default until a

Criterion	Score, 0 to 100	Evidence or comment
		targeted risk analysis says otherwise, which leaves no log population without an interval, and 5.5 specifies what the review record has to contain.
Accuracy	90	Mid-band at 81 to 100 and unmoved. Citations at 5.1 to 5.8 resolve and the 12-month and three-month figures are the v4.0.1 ones. The time-consistency material at 5.7 is written as NorthPay practice and is not attributed to any sub-requirement.
Proportionality and scope fit	95	Entered at 90 then up twice and down once. Up because 5.3 lets automated correlation do the first-stage review provided significant events reach a human and the review leaves evidence behind, which is what makes a daily obligation survivable for a security function of two. Up again because 5.2 answers the SaaS forwarding limitation with a documented equivalent review and retention process rather than a demand the platform cannot meet. Down because 5.6 requires 'protected archival storage' while naming no store, and it never acknowledges that the 90-day window is a licence limit.
Enforceability and clarity	80	Entered at 70 then up three times and down once. Up for named owners: the Information Security Manager is accountable for the process while Engineering owns log enablement and each SaaS system owner carries the audit logs for their own platform. Up for the monthly default cadence that leaves no control without a frequency while an analysis is pending. Up again for 5.5, which sets out what the review record must show: event, reviewer, date, conclusion, action or incident reference. That is what makes a daily review auditable at all. Down for 'retrievable within a reasonable period' at 5.6 and 'the responsible team' at 5.8, neither of which converts into a test.

Criterion	Score, 0 to 100	Evidence or comment
Requirement-area score	93	$(100 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 35 + 22.5 + 19 + 16 = 92.5$, rounded to 93.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.5.1	Clause 5.6 puts protected archival storage behind the 90-day searchable SIEM window. It names no archive, assigns no owner and fixes no implementation date, and it sets retrieval at 'within a reasonable period', which leaves no build instruction anywhere under the 12-month history.	T	Major
10.7.3	The eight response steps at 5.8 go to 'the responsible team', a phrase defined nowhere in the document. Detection and declaration of a critical security control failure are owned by no role.	A	Minor
10.4.1	Automated first-stage review is permitted 'provided significant events are brought to human attention and there is evidence that the review occurred'. State the severity threshold that makes an event significant, and state what form the evidence takes, because without both the exception is wider than the control it sits inside.	T, A	Minor
10.3.1	'Access shall be limited by job need and logged where supported' (5.6). 'Where supported' makes access logging optional, no record is kept of which systems support it, and nobody reviews who holds log read access.	T	Minor
10.4.2.1	The monthly default at 5.4 is a sound interim. Producing the targeted risk analysis meant to replace it has no owner and no date, so the interim quietly becomes the permanent position.	A	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	97	Calculated: 87 of 90 points across the 30 applicable sub-requirements at $100 \times 87 / 90 = 96.7$ which rounds once to 97. Fully addressed 28, largely 1 (12.10.2), partially 1 (12.6.2), not addressed 0. Two deductions: one for the annual review of the awareness programme itself and one for narrowing the incident-response test to 'material elements'.
Accuracy	90	Mid-band at 81 to 100 with nothing to move it and every citation resolving. The UK GDPR material at 11.8 and 12.3 is put as a data-protection obligation and kept away from any PCI DSS sub-requirement, clause 1.4 correctly states that NorthPay holds no FCA permission, and nothing here asserts an obligation the standard does not contain.
Proportionality and scope fit	95	Entered at 90 then up twice and down once. Up for 11.3, which allows a proportionate on-call rota with primary and backup contacts in place of a staffed operations centre, and up again for 15.1, which lets the required records live in controlled spreadsheets, ticketing systems and existing cloud services and says no governance platform need be bought. Down because the same section calls for twenty-one distinct registers, plans and record sets alongside a compliance calendar, and keeping that record estate current is itself a standing demand on one full-time manager and a three-day-a-week analyst.
Enforceability and clarity	80	Entered at 70 then up three times and down once. Up for named owners on the recurring controls: the Information Security Manager holds the scope review, the TRA register and the compliance calendar. Approval sits with the CTO and training follow-up with line managers. Up for the exception process

Criterion	Score, 0 to 100	Evidence or comment
		at section 14, which carries justification, owner, expiry and approval. Up again for the compliance calendar at 13.3, binding each recurring control to a schedule and saying what its evidence must show. Down because nearly every register's population is qualified as 'material' or 'relevant' with no test attached, so what has to be listed cannot be settled.
Requirement-area score	91	$(97 \times 0.35) + (90 \times 0.25) + (95 \times 0.20) + (80 \times 0.20) = 33.95 + 22.5 + 19 + 16 = 91.45$, rounded to 91.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.6.2	Absent: any obligation to review the security awareness programme at least once every 12 months and update it for new threats. Section 9 handles training frequency, content and completion, and never turns back on the programme itself.	A	Major
12.10.2	'The test shall exercise all material elements of the plan' (11.6). The sub-requirement wants every element listed at 12.10.1, and material is undefined, which leaves the tester choosing the scope of their own test.	A	Major
12.3.3, 12.5.1, 12.8.1	The cryptographic inventory, the system-component inventory and the TPSP register are each scoped to 'material' or 'relevant' items with no test for materiality anywhere, so none of them can be shown to be complete.	A	Minor
12.8.2	Clause 10.2 pushes agreements lacking the required acknowledgement out to 'renewal or sooner according to risk' with no long-stop date, so a non-compliant contract can run its full term.	A, L	Minor
12.2.1	Clause 6.3 requires an approved technology list without saying who approves it or how often it is refreshed, and the 'explicit approval by authorized parties' element rests only on the	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	general policy approver at 6.1.		

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	Clause 6.1: documented, published in an accessible location, communicated to affected personnel and relevant third parties, owner and approver assigned, reviewed at least every 12 months; section 15.1 lists authentication and MFA standards among required records.
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	Section 2 assigns duties to the CTO, the Information Security Manager, the Compliance Analyst, system owners and all personnel, and 2.5 requires role security responsibilities in job descriptions.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	Clause 4.1: unique identity before access; accounts not transferred between people; central identity provider and SSO where supported.
8.2.2 Group, shared or generic IDs used only by managed exception	Fully addressed	3	Clause 4.2 carries exceptional use, time limit, documented business reason, explicit management approval,

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			identity verification, withdrawal when the need ends and attribution.
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	Clauses 3.2 and 4.3: approved before implementation, and no more privilege than approved.
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	Clause 4.3: revoked immediately when termination takes effect, and at or before notification where involuntary; manual SaaS de-provisioning must be recorded per service.
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	Clause 4.3: disabled or removed within 90 days of inactivity.
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	Clause 4.4: disabled by default, enabled only for the approved period, logged and monitored, persistent access requiring documented justification and Information Security Manager approval.
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	Clause 4.5 states the 15-minute rule; the remediation sentence that follows is a weakness of enforceability rather than of coverage and is recorded as a finding.
8.3.1 All user and administrator access authenticated by a permitted factor	Partially addressed	1	The enumerated-factor obligation is absent. Clause 4.6 begins 'Authentication factors shall be protected as confidential security credentials' and then goes straight to 'Where passwords or passphrases

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			are used'; no clause states that all access is authenticated by at least one of the three factor types.
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	Clause 4.6: 'Before resetting or modifying an authentication factor, the service desk or administrator shall verify the user's identity using an approved process.'
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	Clause 4.6, items 5 and 6: lock after no more than ten failed attempts, at least 30 minutes or until identity confirmed.
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	Clause 4.6, item 3: temporary or reset passwords unique and changed immediately after first use.
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Largely addressed	2	'They shall contain alphabetic and numeric characters where required by PCI DSS' (4.6, item 2). The 12-character minimum and eight-character fallback are stated correctly; the composition element is stated by reference to the standard rather than as a rule.
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	Clause 4.6, item 4: the previous four passwords shall not be reused.
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	Clause 4.7 lists strong factor selection, protection, non-disclosure, no reuse, rejection of unexpected MFA prompts, immediate change on suspected compromise and prompt reporting.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	Clause 4.6: changed at least every 90 days where the password is the only factor, unless a compliant dynamic posture mechanism determines access in real time.
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Largely addressed	2	'Physical and logical tokens, certificates and other authentication factors assigned to individuals shall not be shared' (4.6). The requirement for physical or logical controls ensuring only the intended user can use the factor is not stated.
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	Clause 4.8, item 2: administrative access into the CDE.
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	Clause 4.8, item 1, with the following paragraph naming the order management platform, PSP merchant portal and other CDE-impacting systems. The 'applicable' qualifier is recorded as a finding rather than a coverage deduction.
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	Clause 4.8, item 3: remote access originating outside NorthPay's network that could access or affect the CDE.
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	Clause 4.9: not used interactively unless exceptional, documented, explicitly approved, limited in duration, linked to an identified individual and logged for attribution.
8.6.2 No hard-coded passwords in scripts,	Fully addressed	3	Clause 4.9: no hard-coding in source code,

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
configuration files or code			scripts or configuration files; approved secrets-management mechanism; repository secrets only where access, audit, encryption and lifecycle controls have been assessed.
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	Clause 4.9: changed immediately on suspected or confirmed compromise and otherwise at a targeted-risk-analysis frequency, with complexity reflecting rotation frequency.

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	Yes, on the written instrument. This is the only one of the four that reads as though somebody had walked the estate before sitting down to write: the legacy project groups, the manual SaaS de-provisioning, the ten-character identity provider minimum, the two-application MFA position, the 90-day SIEM licence, the certificate spreadsheet, the open penetration-test findings and the 78 per cent training rate all turn up as named conditions with a required response against them. I would go at the qualifier layer first. 'Material', 'relevant', 'applicable', 'where technically feasible' and 'where proportionate' run right through the document and every one of them hands the boundary of a control to whoever implements it. An assessor sampling the TPSP register or the cryptographic inventory has no way to establish that either is complete, because the policy doesn't say what has to be in it.
Anything that reads as compliant	Clause 4.5, the session timeout. 'Shall be

Question	Response
on the surface but would not hold.	remediated or otherwise brought into compliance where the requirement applies' has the shape of a remediation commitment and commits to nothing, on the one platform the scenario names as non-compliant and 5.6 is built the same way: 12-month retention stated, 'protected archival storage' behind it and nothing said about where that storage is or who stands it up. Then 11.6, the test of 'all material elements' of the incident response plan, which passes a reading and fails a sample.
Any requirement or sub-requirement missed, misstated or invented.	Nothing invented and no number misattributed. One obligation is genuinely missing: 8.3.1, the general requirement that all access be authenticated by a permitted factor, never appears at all, which leaves passwords and MFA governed while authenticated paths using neither fall outside the document altogether. The scenario names one of those, the SSH key pair on the finance workstation used for the settlement file. Two more obligations arrive with an element dropped, since 7.2.5.1 loses both the management acknowledgement and the addressing of inappropriate access and 8.3.11 loses the control ensuring only the intended user can use a factor. 12.6.2, the annual review of the awareness programme, is absent.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Enforce it, yes. Adopting it as it stands is the harder half. Twenty-two pages, twenty-one required registers and record sets, a compliance calendar and a TRA register make a real standing load for one full-time manager and a three-day-a-week analyst and the document is honest enough to say the records may live in spreadsheets and existing tooling. What makes it feasible is how the work is spread: named system owners approve and review access, engineering owns log enablement, SaaS owners hold their own audit logs and line managers chase training. That is the right shape. The exposure lies in sequencing, because the first year's work is front-loaded

Question	Response
	towards documents that do not yet exist and the policy attaches no dates to any of them.
Anything else worth recording.	Two structural choices stand out — the monthly default log-review interval at 5.4 and the record-content specification at 5.5. Between them they close the gap that swallows most small merchants, where a control acquires a frequency only once an analysis nobody has written appears and where a review has happened only in somebody's recollection. I would run the same treatment over the archive at 5.6 and over the first date for each register.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Senior Security Consultant
Years of experience with PCI DSS	6 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P2a

Date completed: 22 Aug 2026

Reviewer identifier: R3 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	Calculated rather than estimated: 26 of 27 points across the 9 applicable sub-requirements at $100 \times 26 / 27 = 96.3$ which rounds once to 96. Fully addressed 8, largely 1, partially 0, not addressed 0. The section reproduces the sub-requirement text almost word for word which is why the figure comes out this high and the deduction falls on 7.1.2 where the outcome is asserted and no responsibility is assigned. I read the section as a restatement rather than a control set, so the figure and my reading disagree. Both stand. Coverage counts obligations stated and the weakness belongs under the other three criteria.
Accuracy	90	Mid-band at 81 to 100 and unmoved. The text reproduces the sub-requirements almost word for word with correct numbering at every heading, the six-month interval is the v4.0.1 figure and nothing is asserted that the standard does not contain.
Proportionality and scope fit	50	Entered at the 41 to 60 centre because the band description fits: scope statements stay general where the scenario is specific. Section 1 defines application through a generic formula reaching anything that stores, processes or transmits cardholder data and nowhere states that no primary account number rests on a NorthPay system while 2.6 says in the indicative that user access to query repositories of stored

Criterion	Score, 0 to 100	Evidence or comment
		cardholder data is restricted, which reads as a claim that such repositories exist. One step up for the six-month review interval and the least-privilege model, both operable by a function of two and one step down for the 2.6 scope claim. They cancel.
Enforceability and clarity	45	Entered at 50 (the middle of 41 to 60) then up once and down twice, landing at 45. Up because the six-month interval and the four review outcomes are stated and could be tested. Down because section 2 names no performer and no approver: 'authorised personnel' and 'management' are the only actors in the area. Down again for the mood, since the section runs in the indicative throughout, 'Access is assigned', 'Required privileges are approved', which describes a state of affairs and imposes no duty. There's nothing here for anyone to breach.
Requirement-area score	75	$(96 \times 0.35) + (90 \times 0.25) + (50 \times 0.20) + (45 \times 0.20) = 33.6 + 22.5 + 10 + 9 = 75.1$, rounded to 75.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.2	Clause 2.1.2 asserts that roles and responsibilities 'are documented, assigned, and understood' and assigns nothing. Section 2 never names who grants access, who approves a privilege or who runs the six-monthly review.	A	Major
7.2.3	'Required privileges are approved by authorised personnel before access is granted' (2.3.2). Nowhere does authorised personnel resolve to a role or a grade, so as written no approver can be identified and none can be tested.	A	Minor
7.2.4	The six-monthly review has its interval. Nothing else. It lacks a named reviewer, a stated output and any limit on how	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	long inappropriate access may remain once identified.		
7.2.6	Clause 2.6 states in the present indicative that access to repositories of stored cardholder data is restricted and no primary account number rests on any NorthPay system, on the scenario's own account, so the clause describes an environment NorthPay does not have and the last-four-digit records in the order management platform go unaddressed.	A	Minor
7.2.5.1	The review interval for application and system accounts goes wholly to a targeted risk analysis. Clause 5.3.1 requires such analyses to exist and then sets no owner and no interim interval with no date for the first and the scenario states no analysis of this kind has ever been produced.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	Checklist result of 71 of 72 points: $100 \times 71 / 72 = 98.6$ which rounds once to 99. Twenty-three fully addressed and one largely (8.1.2), with nothing partial and nothing absent. Section 3 reproduces every applicable sub-requirement including all elements of 8.2.2, 8.3.8 and 8.6.1. My reading is that the section transcribes the standard with no NorthPay content in it, which the figure contradicts. Both stand because coverage counts obligations stated and this section states them all.
Accuracy	90	Mid-band at 81 to 100 with nothing cited

Criterion	Score, 0 to 100	Evidence or comment
		either way. Every parameter is a v4.0.1 figure with nothing drawn from a superseded version: 12 characters with the eight-character fallback, 10 attempts, 30 minutes, 15 minutes idle, 90 days inactivity, 90 days rotation, four previous passwords. The headings cite the right sub-requirement numbers throughout.
Proportionality and scope fit	55	Entered at 50 (the middle of 41 to 60) and one step up. The band fits because the section never touches the organisation: the identity provider, the ten-character minimum, the six-attempt lockout, the sixty-minute administrative timeout, the order-management session behaviour and the two-application MFA position are all in the scenario and none of them appears here and this section would read identically for any merchant. The step up is because nothing in it demands a capability beyond what the standard itself requires, so a function of two is not being asked for a security operations centre or a tool it does not have.
Enforceability and clarity	50	Entered at 50 then up twice and down twice, so it sits where it started. Up because every authentication parameter is numeric and could be tested straight against a configuration and up because the shared-ID exception at 3.2.2 and the interactive-login exception at 3.5.1 each carry explicit management approval and a time limit. Down because section 3 never names who configures, approves or monitors anything and the only owner in the whole document is the policy owner in document control. Down again for the mood: 'MFA is implemented', 'Access for terminated users is immediately revoked'. Written as existing fact these impose no duty on anybody, and against the environment the scenario describes they are untrue.

Criterion	Score, 0 to 100	Evidence or comment
Requirement-area score	78	$(99 \times 0.35) + (90 \times 0.25) + (55 \times 0.20) + (50 \times 0.20) = 34.65 + 22.5 + 11 + 10 = 78.15$, rounded to 78.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.4.1, 8.4.2, 8.4.3	Clause 3.4 states that MFA 'is implemented' for administrative, non-console and remote access into the CDE. Enforcement today covers the AWS console and the collaboration suite and nothing else, so in the indicative the clause records a state that does not exist with no extension required, no enforcement point named and no date set. Sampled, this would be recorded as not in place.	T	Major
8.3.6, 8.3.4, 8.2.8	The 12-character minimum, the 10-attempt lockout and the 15-minute idle timeout are all stated as existing facts. On the ground it is ten characters, six attempts and sixty minutes for administrative console sessions, with order-management sessions that never time out. Nothing here requires the configuration to change and nobody is given the change to make.	T	Major
8.1.2	Clause 3.1.2 asserts that roles and responsibilities 'are documented, assigned, and understood' and leaves every one of them unallocated. Password standards, MFA enforcement, lockout configuration and de-provisioning have no owner between them.	A	Major
8.2.5	'Access for terminated users is immediately revoked' (3.2.4) and no owner carries it. The software-as-a-service platforms de-provisioned by hand get no per-platform step and nothing has to be evidenced.	A, T	Minor
8.3.8	Clause 3.3.7 requires authentication guidance to be documented and communicated to all users, and author,	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	channel, cadence and record of receipt are all unstated.		
8.6.2	The prohibition on hard-coded credentials at 3.5.2 names no approved secret store and requires nobody to go and look at the repository secrets that hold the deployment credentials.	T	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	96	Calculated: 26 of 27 points across the 9 applicable sub-requirements at $100 \times 26 / 27 = 96.3$ which rounds once to 96. Fully addressed 8, largely 1 (10.1.2), partially 0, not addressed 0. Section 4 reproduces each sub-requirement with all seven elements of 10.7.3 present.
Accuracy	90	Mid-band at 81 to 100 and unmoved. The daily interval, the 12-month history and the three-month immediate availability are all v4.0.1 figures and the headings cite the right numbers.
Proportionality and scope fit	50	At the centre of 41 to 60 because scope statements stay general where the scenario is specific. Section 4 acknowledges none of it: the 90-day SIEM licence, the absent archive, the order-management administrator log that is never forwarded, the shared mailbox watched 08:00 to 18:00 on working days. One step down because a daily review of all security events with no reviewer and no allowance for automated triage is not operable by a function of two as written and one step up because nothing in the area demands capability beyond the cloud logging and SIEM already in place. They cancel.
Enforceability and clarity	50	Centre of the 41 to 60 band with one step each way. Up because the daily interval and the 12-month and three-month retention figures are numeric and

Criterion	Score, 0 to 100	Evidence or comment
		testable. Down because no reviewer, investigator or owner is named anywhere, nothing states what a completed review produces and the section reads in the indicative as description rather than duty.
Requirement-area score	76	$(96 \times 0.35) + (90 \times 0.25) + (50 \times 0.20) + (50 \times 0.20) = 33.6 + 22.5 + 10 + 10 = 76.1$, rounded to 76.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.5.1	'Audit log history is retained for at least 12 months, with at least the most recent three months immediately available' (4.4.1), put as an existing fact. In reality the SIEM holds 90 days under licence, older logs are deleted or overwritten and no archive has been configured and nothing here requires an archive, names one, assigns it or dates it.	T	Major
10.1.2	Clause 4.1.2 asserts that responsibilities for Requirement 10 activities are documented, assigned and understood. Nobody ends up holding any of them.	A	Major
10.4.1	The daily review names no reviewer and requires no record that it happened. Automated first-stage triage isn't permitted and non-working days go unmentioned.	A	Minor
10.4.2, 10.4.2.1	The periodic interval for other components goes wholly to a targeted risk analysis with no interim default behind it. The order-management administrator log, visible only in that platform's interface and never forwarded to the SIEM, appears nowhere in section 4.	A	Minor
10.4.3	'Exceptions and anomalies identified during the review process are addressed' (4.3.4). No owner and no time limit. No escalation route either.	A	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	99	Calculated: 89 of 90 points across the 30 applicable sub-requirements at $100 \times 89 / 90 = 98.9$ which rounds once to 99. Fully addressed 29, largely 1 (12.1.4), partially 0, not addressed 0. Section 5 reproduces every applicable sub-requirement including 12.3.2, 12.3.3, 12.3.4 and all seven parts of 12.10. I read section 5 as a transcription of the standard that produces no organisational commitment at all and the figure contradicts that. Both stand.
Accuracy	90	Mid-band at 81 to 100 with nothing to move it. The sub-requirement number at every heading resolves to the obligation stated beneath it, the 12-month intervals are correct throughout and nothing is asserted that the standard does not contain.
Proportionality and scope fit	50	Centre of 41 to 60 because scope statements stay general where the scenario is specific. Section 5 mentions none of the eleven suppliers touching the cloud environment, the absent incident response plan, the 78 per cent training completion, the missing cryptographic inventory or the two-person security function. Clause 5.1.4 requires assignment to a Chief Information Security Officer or knowledgeable executive and names nobody, in an organisation with no CISO and a PCI DSS programme owned informally. Down once for 5.8.3, which designates 24/7 availability with no rota and no routing and up once because nothing here demands a governance platform or headcount the standard does not itself require. They cancel.
Enforceability and clarity	50	Entered at 50 then up twice and down twice. Up because the 12-month

Criterion	Score, 0 to 100	Evidence or comment
		intervals are stated throughout and can be tested and up again because document control names an owner and an approver and section 6 sets an annual review alongside an annual acknowledgement. Down because section 5 never says who maintains the supplier register, the cryptographic inventory, the component inventory or the incident response plan. Down again because the whole section runs in the indicative, leaving twenty-one obligations describing a state of affairs while requiring nobody to bring it about.
Requirement-area score	77	$(99 \times 0.35) + (90 \times 0.25) + (50 \times 0.20) + (50 \times 0.20) = 34.65 + 22.5 + 10 + 10 = 77.15$, rounded to 77.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.10.1	Clause 5.8.1 specifies the plan's contents and states that the plan 'exists and is ready to be activated'. No security-specific incident response plan has been written and no roles have been assigned and nothing here requires the plan to be produced, names its author or sets a date for it.	A	Major
12.8.1, 12.8.2, 12.8.3, 12.8.4, 12.8.5	The supplier register, the written agreements, the due diligence process, the annual compliance monitoring and the responsibility matrix are all stated in the indicative as things that exist. No register is maintained and no due diligence is carried out, nobody is assigned to produce any of the five and no date attaches to any of them either.	A	Major
12.1.4	Clause 5.1.4 reproduces the requirement and names nobody. NorthPay has no Chief Information Security Officer and the Chief Technology Officer owns the programme without that ever having been written down and this document	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	does not write it down either.		
12.3.1	Targeted risk analyses are required at 5.3.1 with nobody assigned to produce them and no date set. Four intervals elsewhere in the policy wait on them.	A	Minor
12.6.3	Training is required on hire and annually with acknowledgement. No owner is named, and non-completion carries neither a threshold nor an escalation route, against a completion rate of 78 per cent last year.	A	Minor
12.2.1	The approved product list is required. Nobody is named to compile it or to keep it current and the personal devices in use for email and calendar are not addressed anywhere.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Fully addressed	3	Clause 3.1.1 reproduces all four elements.
8.1.2 Roles and responsibilities documented, assigned and understood	Largely addressed	2	Clause 3.1.2 asserts that roles 'are documented, assigned, and understood' but assigns nothing; no role is named anywhere in section 3.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	Clause 3.2.1: unique ID before access is allowed.
8.2.2 Group, shared or generic IDs used	Fully addressed	3	Clause 3.2.2 reproduces all six management conditions.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
only by managed exception			
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	Clause 3.2.3: authorised with appropriate approval, implemented with only the privileges on the documented approval.
8.2.5 Access for terminated users revoked immediately	Fully addressed	3	Clause 3.2.4: immediately revoked.
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	Clause 3.2.5: removed or disabled within 90 days of inactivity.
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	Clause 3.2.6: enabled only during the period needed, disabled when not in use, use monitored for unexpected activity.
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	Clause 3.2.7: re-authentication after more than 15 minutes idle.
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	Clause 3.3.1 enumerates all three factor types.
8.3.3 Identity verified before an authentication factor is changed	Fully addressed	3	Clause 3.3.2: identity verified before modifying any authentication factor.
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	Clause 3.3.3: lockout after not more than 10 attempts, minimum 30 minutes or until identity confirmed.
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	Clause 3.3.4: unique value for first use and reset, forced change immediately after first use.
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	Clause 3.3.5: minimum 12 characters with the eight-character fallback, numeric and alphabetic.
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	Clause 3.3.6: not the same as any of the last four.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.8 Authentication policies documented and communicated to all users	Fully addressed	3	Clause 3.3.7 carries all four guidance elements including how to report a suspected compromise.
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	Clause 3.3.8: at least every 90 days, or dynamic posture analysis determining access in real time.
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	Clause 3.3.9: assigned to an individual, not shared, with physical or logical controls ensuring only the intended user can use the factor.
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	Clause 3.4.1.
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	Clause 3.4.2.
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	Clause 3.4.3.
8.6.1 Interactive login by system or application accounts controlled	Fully addressed	3	Clause 3.5.1 reproduces all six conditions on interactive use.
8.6.2 No hard-coded passwords in scripts, configuration files or code	Fully addressed	3	Clause 3.5.2: not hard coded in scripts, configuration or property files, or bespoke and custom source code.
8.6.3 System and application account passwords protected and changed periodically	Fully addressed	3	Clause 3.5.3: changed at a targeted-risk-analysis frequency and on suspicion or confirmation of compromise, with complexity appropriate to that frequency.

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	No. It would pass a reading and fail the first sample. Every applicable sub-requirement is present and correctly numbered, which is why the coverage arithmetic comes back in the high nineties while the document itself is the standard transcribed into the present indicative. My first challenge would be to the mood of the thing: 'MFA is implemented', 'Access for terminated users is immediately revoked', 'An incident response plan exists'. Each of those is an assertion of fact about an organisation where MFA covers two applications, de-provisioning is done by hand and nobody has written an incident response plan. Assert that a control is in place and you hand the assessor a set of statements to disprove while moving the organisation towards nothing.
Anything that reads as compliant on the surface but would not hold.	Almost all of it. These coverage figures are the clearest case in the set of the calculation disagreeing with the reading, and I have recorded that in three of the four areas rather than bending the ratings to fit. Clause 3.4, MFA, would be written up as not in place. Clause 4.4.1, twelve-month log retention, runs straight into a 90-day licence and no archive. Clauses 5.7.1 to 5.7.5 describe a supplier register and a due-diligence process that do not exist and 5.8.1 asserts an incident response plan nobody has written.
Any requirement or sub-requirement missed, misstated or invented.	None missed and none invented. The requirement text is accurate, the numbering is right at every heading and the parameters are current including the 12-character minimum with its eight-character fallback. One deduction falls in each of Requirements 7, 8, 10 and 12 and every time it lands on the roles and responsibilities sub-requirement, where the document asserts responsibilities are assigned and assigns none. That is its characteristic failure at 7.1.2, 8.1.2, 10.1.2 and 12.1.4.
Could an organisation of sixty-	Adopt, trivially. It asks nothing of anyone.

Question	Response
one people, with a security function of two, realistically adopt and enforce this policy as written?	Enforce, no. Outside the document owner in the front matter there is no owner for any control, no date by which anything has to be true and no obligation a named person could be held to. NorthPay's actual environment never appears either: no identity provider, no SIEM, no payment service provider, no two-person function. Adopt this and every configuration gap in the scenario stays exactly where it is and a written record says the organisation believes them closed.
Anything else worth recording.	As a checklist of what has to be covered it is worth something and the coverage figures reflect that fairly. As an instrument it is worth almost nothing. Two moves would take it most of the way towards something usable: put the indicative into the imperative and attach a named role to each clause. A remediation annex covering the configurations that sit short of the parameters written here would finish the job. Until that happens the high coverage figures on this sheet say nothing about whether the policy is sound.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Senior Security Consultant
Years of experience with PCI DSS	6 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.

Appendix D Reviewer Response Capture Form

Part 1 Guidance and calibration

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Appendix D1. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25

Criterion	What it measures	Weight
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place

Severity	Definition
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8	13	90	65	30	46
Second, Section D.9	46	90	90	80	73

Table D.15: Calibration scores.

Part 2 The scoring form

D.13 Scoring

Policy code under review: P2b

Date completed: 22 Aug 2026

Reviewer identifier: R3 (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	89	Calculated rather than estimated: 24 of 27 points across the 9 applicable sub-requirements at $100 \times 24 / 27 = 88.9$ which rounds once to 89. Fully addressed 6, largely 3 (7.1.1, 7.2.1, 7.2.5.1), partially 0, not addressed 0. What comes off the total is the missing requirement that supporting Requirement 7 procedures be documented and kept current, the missing access control model as such, and two dropped elements in the application and system account review.
Accuracy	90	Mid-band at 81 to 100 and unmoved. The six-month interval is the v4.0.1 figure and the citations at section 2 resolve, the statement at 3.6 that only the last four digits are held alongside personal data matches the scenario and nothing is asserted that the standard does not contain.
Proportionality and scope fit	70	Entered at 70 (the middle of 61 to 80) with one step each way. Up because approval runs to roles that actually exist, with line managers raising requests and the Information Security Manager or CTO approving, and because 3.6 ties least privilege to the last-four-digit records that are genuinely held. Down because section 1 defines the cardholder data environment as comprising the storefront, checkout page, order-management platform and administrator access paths. Those

Criterion	Score, 0 to 100	Evidence or comment
		systems connect to the environment or can impact it and they do not constitute it, and rolling the two categories together widens every downstream obligation without saying so.
Enforceability and clarity	75	Entered at 70 then up twice and down once. Up for 3.2, which names the requester and the approver and marks privileged approval out separately and that is the one place across the four policies where an access approval could actually be traced end to end. Up again because section 2 gives access control an owner and hands line managers a defined part in the six-monthly review. Down because 'Any unnecessary access is removed' at 3.3 sets no time limit and because the application and system account review at 3.4 has no interim interval while the targeted risk analysis is pending.
Requirement-area score	83	$(89 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (75 \times 0.20) = 31.15 + 22.5 + 14 + 15 = 82.65$, rounded to 83.

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
7.1.1	No clause requires the operational procedures supporting Requirement 7 to be documented, kept up to date, in use and known to affected parties, while section 8 lists access-request and review records among the related documents and puts no obligation on anyone to maintain them.	A	Major
7.2.1	Clause 3.1 states least privilege and job classification and stops short of defining an access control model. Nothing requires access to be matched to the entity's business and access needs and nothing requires a role-to-system mapping to be kept, so with fourteen identity provider groups in use and three of them obsolete, nothing in	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	this section would surface the mismatch.		
7.2.5.1	Clause 3.4 carries the management acknowledgement and drops the element requiring inappropriate application and system account access to be addressed and the interval goes to a targeted risk analysis with no interim frequency behind it.	A	Major
7.2.4	'Any unnecessary access is removed' (3.3). Say within how many days, and say what happens when removal does not follow the review. Neither is stated.	A	Minor
7.2.6	Clause 3.5 extends the restriction to 'any repository that holds cardholder data (or data that could lead to it)'. The parenthesis has no definition and could reach any customer record, so as written the systems covered cannot be determined.	A	Minor
7.2.3	Every access approval runs to the Information Security Manager, or to the CTO for privileged roles. No delegation is stated and no cover for absence, and with one full-time manager in the security function approval becomes a single point of failure.	A	Minor

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	88	Checklist result of 63 of 72 points: $100 \times 63 / 72 = 87.5$ which rounds once to 88. Seventeen fully addressed and six largely, none partially and one not addressed at all. The single absence is 8.3.3, identity verification before an authentication factor is changed and the

Criterion	Score, 0 to 100	Evidence or comment
		six other deductions are dropped elements rather than missing topics.
Accuracy	90	Mid-band at 81 to 100 with nothing either way. All parameters are v4.0.1 figures: 12 characters with the eight-character fallback, 10 failures, 30 minutes, 15 minutes, 90 days inactivity, 90 days rotation, four previous passwords. Clause 4.9's statement that MFA is currently enforced on the AWS console and collaboration suite is accurate and no obligation is asserted that the standard does not contain.
Proportionality and scope fit	75	Entered at 70 then up twice and down once. Up because 4.9 names the current two-application MFA position and requires extension to the order management platform, the PSP merchant portal and the helpdesk, all federated to a provider that supplies MFA and up again because every control in the section lands where the organisation can reach it rather than on tooling it does not have. Down for the scope error that runs through the document, since section 1 has the storefront, checkout page, order-management platform and administrator paths comprising the cardholder data environment when the scenario puts them outside it as connected or impacting systems.
Enforceability and clarity	70	Centre of 61 to 80 with two steps up and two back down. Up because section 2 gives authentication a named owner and up because every password, logout, timeout and MFA parameter is a number. Down because the exception approvers at 4.1 and 4.11 are 'management' and go unnamed with no maximum duration on either exception. Down again for 4.11, which characterises application and system account handling, 'are treated as exceptional, time-limited, approved and

Criterion	Score, 0 to 100	Evidence or comment
		attributable' while requiring nothing and calling for no approval record.
Requirement-area score	82	$(88 \times 0.35) + (90 \times 0.25) + (75 \times 0.20) + (70 \times 0.20) = 30.8 + 22.5 + 15 + 14 = 82.3$, rounded to 82.

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
8.3.3	Absent. No clause requires a user's identity to be verified before an authentication factor is modified. Clause 4.2 requires approval for the addition, modification or deletion of authentication factors and that is a different control: approval authorises the change and it doesn't establish that the person asking is the account holder, which leaves the helpdesk reset path uncontrolled.	T, A	Critical
8.2.5	'Access for terminated users is revoked immediately on the last working day (or sooner if the circumstances require)' (4.3). Termination is the sub-requirement's trigger and the end of the last working day is a later one, so under this wording somebody terminated mid-notice keeps access until that date.	A	Major
8.6.1	Clause 4.11 states that application and system accounts allowing interactive login 'are treated as exceptional, time-limited, approved and attributable to an individual'. Two elements are missing behind that: a documented business justification, and confirmation of the individual's identity before access is granted.	T, A	Major
8.2.2	Clause 4.1 drops the confirmation of individual identity before access to a shared account is granted and the only approver named is 'management'.	A	Major
8.1.1	Nothing requires the operational procedures supporting Requirement 8 to be documented, kept current, in use	A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	and known to affected parties.		
8.6.3	Clause 4.11 omits the requirement that application and system account credentials be built with complexity appropriate to the rotation frequency and no interim rotation interval is set while the targeted risk analysis is outstanding.	T	Minor
8.3.8	Clause 4.12 covers the reporting of suspicion and omits the instruction to change a password where compromise is suspected or known, and issuing the guidance carries no cadence and leaves no record.	A	Minor

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	93	Calculated: 25 of 27 points across the 9 applicable sub-requirements at $100 \times 25 / 27 = 92.6$ which rounds once to 93. Fully addressed 7, largely 2 (10.1.1 and 10.7.3), partially 0, not addressed 0. Two deductions: no requirement that the logging and monitoring procedures be documented and kept current and no documented remediation in the control-failure response.
Accuracy	90	Mid-band at 81 to 100 and unmoved. The daily interval and the 12-month and three-month retention figures are the v4.0.1 ones and the parentheses at 5.3 and 5.6, that NorthPay stores no full PANs and that current SIEM retention is 90 days, are both accurate.
Proportionality and scope fit	75	Entered at 70 then up twice and down once. Up because 5.6 names the real constraint, a 90-day SIEM retention, and puts a concrete remedy against it in extension or offline archive and up again for the closing paragraph, which sets a three-month deadline for defining retention schedules and is the only

Criterion	Score, 0 to 100	Evidence or comment
		dated commitment anywhere in the document. Down because the daily review at 5.3 names no reviewer, allows no automated first-stage triage and says nothing about non-working days while the security function is two people and the alert mailbox is watched 08:00 to 18:00 on working days.
Enforceability and clarity	70	Centre of 61 to 80 with two steps up and two down. Up because section 2 gives logging and monitoring a named owner and up because the retention-schedule obligation carries a definite three-month deadline. Down for 5.6's archive commitment, 'will be extended or supplemented by offline archive', which names neither an archive nor an owner and sets no date, and which reads as a prediction rather than a duty. Down again because nothing has to be recorded to show the daily review took place.
Requirement-area score	84	$(93 \times 0.35) + (90 \times 0.25) + (75 \times 0.20) + (70 \times 0.20) = 32.55 + 22.5 + 15 + 14 = 84.05$, rounded to 84.

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
10.5.1	'Current SIEM retention of 90 days will be extended or supplemented by offline archive to meet this requirement' (5.6). Nothing names the archive, assigns an owner, sets a date or requires the archived history to be protected against alteration and deletion. Behind the twelve-month history sits an expectation and nothing else.	T	Major
10.4.2, 10.4.2.1	The periodic interval for other components goes wholly to a targeted risk analysis with no interim default. There's no mention in section 5 of the order-management administrator log, which is visible only in that platform's interface and never reaches the SIEM,	T, A	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	so neither the daily nor the periodic population can be determined.		
10.1.1	No clause requires the logging and monitoring procedures supporting Requirement 10 to be documented, kept up to date, in use and known to affected parties, and section 8 leaves them out of the related documents as well.	A	Major
10.4.1	Nobody is named to perform the daily review. It leaves no required record and non-working days are not provided for.	A, T	Minor
10.7.3	Clause 5.7 requires the duration and cause of a failure to be recorded. The remediation determined is left undocumented and the sub-requirement lists it separately from the cause.	A	Minor

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage	78	Calculated: 70 of 90 points across the 30 applicable sub-requirements at $100 \times 70 / 90 = 77.8$ which rounds once to 78. Fully addressed 19, largely 6, partially 1, not addressed 4. The four absences are 12.3.2, 12.3.3, 12.3.4 and 12.6.2 and the partial is 12.10.5 where no alert source is named.
Accuracy	90	Mid-band at 81 to 100 with nothing to move it. The citations at section 2 resolve, the 12-month intervals are correct and the targeted-risk-analysis dependencies at 6.3 name 7.2.5.1, 8.6.3, 10.4.2.1 and 12.10.4.1 all four correctly, while the UK GDPR seventy-two hour duty at 6.8 is put as a legal obligation and kept off any PCI DSS sub-requirement and no obligation is asserted that the standard does not contain. The misstatement at 6.2 about conditional access is a claim about the

Criterion	Score, 0 to 100	Evidence or comment
		environment rather than about the standard and I have scored it under the next criterion.
Proportionality and scope fit	70	Centre of 61 to 80 with two steps up and two down. Up because section 2 maps duties onto roles that exist, the three-day-a-week Compliance Analyst and the Head of Finance and Legal among them and up because 6.5 takes the 78 per cent training completion head-on and the closing paragraph of section 5 puts a date on the retention-schedule commitment. Down because 6.2 states that the personal-device restriction 'is enforced by conditional-access policy' when it is enforced by convention, which records a control as operating when it is not. Down again for 6.8 and its designation of 24/7 availability with no rota or deputy and no alert routing, for a function of two.
Enforceability and clarity	70	Centre of 61 to 80 with two up and two down. Up because section 2 attaches a named role to every governance activity in the area and up because annual intervals are stated throughout and the retention-schedule obligation carries a definite date. Down because the incident response plan, the supplier register and the responsibility matrix are all written as though they exist with no owner and no first-production date while none of them does. Down again because the targeted risk analyses at 6.3 have no owner and no date either, which leaves four intervals undefined on the day of adoption.
Requirement-area score	78	$(78 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (70 \times 0.20) = 27.3 + 22.5 + 14 + 14 = 77.8$, rounded to 78.

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.3.3	Absent. Nothing requires an inventory	T	Major

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
	of cryptographic cipher suites and protocols, an annual review of it, monitoring of their continued viability or a plan for anticipated cryptographic change. No such inventory exists today and certificate expiry lives in a spreadsheet held by one engineer.		
12.3.4	Absent. Nothing requires hardware and software technologies to be reviewed at least every 12 months for continued vendor support, continued PCI DSS compliance, end-of-life announcements or a senior-management-approved remediation plan.	T	Major
12.6.2	Absent. Clause 6.5 handles training frequency, content and a completion target and never turns to the awareness programme itself, which has to be reviewed at least every 12 months and updated for new threats.	A	Major
12.10.5	'The plan includes monitoring and response to alerts from security systems' (6.8). None of the five alert sources the sub-requirement lists is named and the payment-page change-and-tamper-detection mechanism is absent from the document entirely, in a policy written for a merchant serving its own checkout page.	T	Major
12.2.1	'This restriction is enforced by conditional-access policy' (6.2). Personal devices reaching CDE-connected systems are held back by convention and no conditional-access policy does it, so the clause records a control as operating where it should be requiring one to be implemented. No approved product list is called for either.	T	Major
12.3.2	Absent. Nothing addresses the targeted risk analysis required where a requirement is met by the customized approach, with its controls matrix, its senior-management approval and its annual performance.	A	Minor

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity
12.10.7	Clause 6.8 covers retrieval, secure deletion or migration, source and remediation on discovery of unexpected PAN, and identifying whether sensitive authentication data sits alongside it drops out.	T	Minor
12.5.1	Clause 6.4 requires an inventory of in-scope system components without the description of each component's function or use that the sub-requirement calls for.	A	Minor
12.10.2	Clause 6.8 requires the plan to be reviewed and tested at least annually and stops short of requiring the test to cover all elements listed in 12.10.1.	A	Minor
12.3.1	Clause 6.3 omits the element requiring an updated analysis where the annual review determines one is needed, and owner and first-production date for the analyses are both unstated.	A	Minor

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties	Largely addressed	2	Document control requires publication on the intranet, issue to all staff and relevant suppliers and annual acknowledgement, and section 7 sets annual review, but no clause requires the operational procedures supporting Requirement 8 to be documented, kept current and in use.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.2 Roles and responsibilities documented, assigned and understood	Fully addressed	3	Section 2 cites 8.1.2 and gives the Information Security Manager day-to-day ownership of authentication, with duties also set for line managers and all personnel.
8.2.1 Unique ID assigned to every user before access is allowed	Fully addressed	3	Clause 4.1: unique identifier before any access is granted.
8.2.2 Group, shared or generic IDs used only by managed exception	Largely addressed	2	'Shared, group or generic accounts are forbidden except in documented, time-limited exceptional circumstances that are approved by management and that still allow actions to be attributed to an individual' (4.1). Confirmation of the individual's identity before access is granted is not required, and the approver is not named.
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges	Fully addressed	3	Clause 4.2: prior documented approval, implemented only with the privileges stated on that approval.
8.2.5 Access for terminated users revoked immediately	Largely addressed	2	'Revoked immediately on the last working day (or sooner if the circumstances require)' (4.3). The sub-requirement's trigger is termination; tying revocation to the last working day is weaker.
8.2.6 Inactive accounts removed or disabled within 90 days	Fully addressed	3	Clause 4.3: inactive accounts disabled or

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			removed within 90 days of inactivity.
8.2.7 Third-party remote support accounts enabled only when needed and monitored	Fully addressed	3	Clause 4.4: enabled only for the period required, disabled when not in use, activity monitored.
8.2.8 Re-authentication required after 15 minutes idle	Fully addressed	3	Clause 4.5: sessions idle for more than 15 minutes require re-authentication.
8.3.1 All user and administrator access authenticated by a permitted factor	Fully addressed	3	Clause 4.6 enumerates all three factor types for all access.
8.3.3 Identity verified before an authentication factor is changed	Not addressed	0	Absent. Clause 4.2 requires approval for a change to an authentication factor but nothing requires the user's identity to be verified before the change is made.
8.3.4 Invalid authentication attempts limited by lockout	Fully addressed	3	Clause 4.8: lock after no more than 10 failures, minimum 30 minutes or until identity is confirmed.
8.3.5 First-time and reset passwords set uniquely and changed on first use	Fully addressed	3	Clause 4.7: set to a unique value on first use or reset and forced to change immediately.
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic	Fully addressed	3	Clause 4.7: minimum 12 characters, or 8 where the system cannot support 12, containing numeric and alphabetic characters.
8.3.7 No reuse of any of the last four passwords	Fully addressed	3	Clause 4.7: cannot be the same as any of the last four passwords used.
8.3.8 Authentication policies documented and communicated to all users	Largely addressed	2	Clause 4.12 covers selection, protection, no reuse and reporting suspicion of

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
			compromise, but omits the instruction to change the password where compromise is suspected or known.
8.3.9 Password changed at least every 90 days, or dynamic access analysis	Fully addressed	3	Clause 4.7: changed at least every 90 days where the password is the sole factor, or the account is subject to continuous risk-based analysis.
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected	Fully addressed	3	Clause 4.10: assigned to individuals and protected so that only the intended user can use them.
8.4.1 MFA for all non-console administrative access into the CDE	Fully addressed	3	Clause 4.9, first bullet.
8.4.2 MFA for all non-console access into the CDE	Fully addressed	3	Clause 4.9, second bullet, with explicit extension to the order management platform, PSP merchant portal, helpdesk platform and any other CDE-affecting system.
8.4.3 MFA for all remote access originating outside the network	Fully addressed	3	Clause 4.9, third bullet: remote access from outside the NorthPay network that can reach or impact the CDE.
8.6.1 Interactive login by system or application accounts controlled	Largely addressed	2	'Are treated as exceptional, time-limited, approved and attributable to an individual' (4.11). Documented business justification and confirmation of the individual's identity before access are not required.
8.6.2 No hard-coded passwords in scripts,	Fully	3	Clause 4.11: 'Their

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
configuration files or code	addressed		passwords are never hard-coded.'
8.6.3 System and application account passwords protected and changed periodically	Largely addressed	2	Clause 4.11 requires periodic change at the targeted-risk-analysis frequency and immediate change on suspicion of compromise, but omits complexity appropriate to the change frequency.

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	Partly. Requirements 7, 8 and 10 would stand up to a first pass and Requirement 12 would not, because four whole sub-requirements are missing rather than weak. First challenge: the cardholder data environment definition in section 1. It has the environment comprising the storefront, checkout page, order-management platform, administrator access paths and anything connecting to them. Those systems connect to the environment or can impact it. They are not the environment. That distinction changes what 8.4.2 bites on and what the scope validation at 6.4 has to confirm, and an error in the opening section carries through everything after it. After that, 6.2, which states as fact that conditional access enforces the personal-device restriction when nothing of the kind is configured.
Anything that reads as compliant on the surface but would not hold.	Clause 6.2, the personal-device restriction 'enforced by conditional-access policy'. It reads as a control statement and describes something nobody has configured, so it would be recorded as not in place. Clause 5.6's archive, 'will be extended or supplemented by offline archive to meet

Question	Response
	this requirement', reads as a retention commitment and is a prediction with no archive, no owner and no date. Clause 4.11 as well: 'are treated as exceptional' is a characterisation rather than a rule and nothing has to be recorded when a system account is used interactively.
Any requirement or sub-requirement missed, misstated or invented.	Four sub-requirements are missed outright in Requirement 12. 12.3.3, the cryptographic inventory, and 12.3.4, the technology lifecycle review, are absent in any form, which bites here because no inventory exists and certificate expiry sits in one engineer's spreadsheet. 12.6.2, the annual review of the awareness programme, is gone, and so is 12.3.2. The most serious single omission sits elsewhere, in Requirement 8: 8.3.3, identity verification before an authentication factor is changed, which leaves the credential-reset path open with only an approval step in front of it. Nothing is invented and no parameter comes from a superseded version.
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	Yes, and of the four this is the one most likely actually to be operated. Five pages. Roles mapped onto the people who exist, a defined job for the part-time analyst and another for line managers, the 78 per cent training figure named with a target set against it, the SIEM limit named and one dated commitment in the whole document. That is what adoption looks like at sixty-one people. The proportionality is bought with the four missing Requirement 12 sub-requirements and the thinness at 4.11 and 6.8, and both of those are fixable in a page.
Anything else worth recording.	This document does one thing better than anything else I have read across the four: it puts a date on something. 'Retention schedules be defined and documented within three months of adoption' is the only clause anywhere that says when. Run the same device over the log archive at 5.6, the incident response plan at 6.8 and the supplier register at 6.7, and most of what is wrong here closes. One other thing. The

Question	Response
	coverage figure for Requirement 12, 78, is the only one on any of my four sheets that matches my reading of the section without qualification.

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	Senior Security Consultant
Years of experience with PCI DSS	6 years
Currently or formerly a Qualified Security Assessor	Not a QSA

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.